UNIVERSIDADE DO VALE DO ITAJAÍ
ESCOLA POLITÉCNICA
CURSO DE CIÊNCIA DA COMPUTAÇÃO

Segurança de Sistemas Computacionais

Diego Fonseca da Silva
Leonardo Pacheco B Dias
Gustavo Gonçalves Trindade
João Victor Rodrigues Santos

MODELAGEM DE AMEAÇAS NO OWASP JUICE SHOP

TRABALHO 2

Relatório final de modelagem com DFD e STRIDE

Professor Ramicés dos Santos Silva

Itajaí (SC)
Novembro de 2026

RESUMO

Este trabalho modela ameaças do OWASP Juice Shop v20.2.0, aplicação de comércio eletrônico desenvolvida para ensino de segurança. O objetivo é identificar em quais pontos do sistema os dados e as permissões ficam expostos e propor controles verificáveis para a arquitetura analisada. O modelo utiliza diagramas de fluxo de dados de contexto e detalhado, com recortes de login e sessão, cadastro e recuperação de senha, cesta e pedido, administração e contabilidade. A análise aplica STRIDE por elemento e prioriza os cenários pelo método DREAD. As evidências HTTP e as capturas do Trabalho 1 foram comparadas com o código da versão e seus testes publicados. O registro reúne 25 cenários, dos quais sete se apoiam em evidências do laboratório anterior e 18 permanecem plausíveis. A injeção SQL no login obteve a maior pontuação, 9,8, por permitir a entrada como administrador a partir de uma requisição anônima. A análise também apontou falhas de titularidade na cesta, exposição de hash em token, recuperação de senha por resposta previsível e verificações de papel desiguais entre rotas administrativas e contábeis. O plano de tratamento associa requisitos do OWASP ASVS 5.0.0 e critérios de aceite a cada cenário, considerando a proteção de dados pessoais nos fluxos analisados.

Palavras-chave modelagem de ameaças. DFD. STRIDE. DREAD. OWASP Juice Shop.

QUADRO DE PARTICIPAÇÃO

Integrante	Fluxo proposto	Contribuição documentada na fundamentação
Diego Fonseca da Silva	FX1	Fundamentação teórica, implantação, atores, ativos e pontos de entrada (C3 a C6).
Leonardo Pacheco B Dias	FX2	Inventário e justificativa dos fluxos candidatos (C8).
Gustavo Gonçalves Trindade	FX3	Dependências, premissas, relação com a M1 e revisão de C6 e C8.
João Victor Rodrigues Santos	FX4	Identificação, arquitetura e fundamentação do DFD inicial (C1 e C2).

A distribuição dos fluxos para a revisão final segue a proposta do Quadro de Participação. As contribuições anteriores foram mantidas conforme o registro da pesquisa inicial. A confirmação da atribuição final e da revisão cruzada cabe à equipe.

LISTA DE FIGURAS

Figura 1 - DFD de contexto do OWASP Juice Shop 19
Figura 2 - DFD detalhado e fronteiras de confiança 20
Figura 3 - Recorte do DFD do FX1 24
Figura 4 - Recorte do DFD do FX2 34
Figura 5 - Recorte do DFD do FX3 44
Figura 6 - Recorte do DFD do FX4 56
Figura 7 - Sessão administrativa obtida no ensaio V1 77
Figura 8 - Campo de hash no JWT da evidência V2 77
Figura 9 - Resposta de cesta alheia no ensaio V3 78
Figura 10 - Detalhes do framework em resposta de erro V4 79
Figura 11 - Diretório público identificado no ensaio V5 79
Figura 12 - Sessão de administrador obtida por injeção SQL (reprodução M2) 81
Figura 13 - Listagem anônima do diretório /ftp/ (reprodução M2) 81

LISTA DE QUADROS

Quadro 1 - Categorias STRIDE e propriedades de segurança 9
Quadro 2 - Atores e permissões esperadas 12
Quadro 3 - Ativos e classificação de dados 13
Quadro 4 - Superfície de ataque por categoria 13
Quadro 5 - Dependências e funções de segurança 14
Quadro 6 - Fluxos candidatos e critérios de seleção 15
Quadro 7 - Rastreabilidade dos achados da M1 16
Quadro 8 - Âncoras para atribuição das notas DREAD 18
Quadro 9 - Inventário dos elementos do DFD 21
Quadro 10 - Fronteiras de confiança 22
Quadro 11 - Entradas do recorte e elementos afetados 23
Quadro 12 - Identificação e condições do FX1 23
Quadro 13 - Requisições e evidências do FX1 24
Quadro 14 - Elementos percorridos no FX1 24
Quadro 15 - Classificação dos dados no FX1 25
Quadro 16 - Controles identificados no FX1 25
Quadro 17 - Matriz STRIDE do FX1 26
Quadro 18 - Parte A do FX1 Identificação das ameaças 29
Quadro 19 - Parte B do FX1 Priorização e tratamento 31
Quadro 20 - Identificação e condições do FX2 34
Quadro 21 - Requisições e evidências do FX2 34
Quadro 22 - Elementos percorridos no FX2 35
Quadro 23 - Classificação dos dados no FX2 35
Quadro 24 - Controles identificados no FX2 35
Quadro 25 - Matriz STRIDE do FX2 36
Quadro 26 - Parte A do FX2 Identificação das ameaças 39
Quadro 27 - Parte B do FX2 Priorização e tratamento 40
Quadro 28 - Identificação e condições do FX3 43
Quadro 29 - Requisições e evidências do FX3 44
Quadro 30 - Elementos percorridos no FX3 45
Quadro 31 - Classificação dos dados no FX3 46
Quadro 32 - Controles identificados no FX3 46
Quadro 33 - Matriz STRIDE do FX3 47
Quadro 34 - Parte A do FX3 Identificação das ameaças 51
Quadro 35 - Parte B do FX3 Priorização e tratamento 52
Quadro 36 - Identificação e condições do FX4 56
Quadro 37 - Requisições e evidências do FX4 56
Quadro 38 - Elementos percorridos no FX4 57
Quadro 39 - Classificação dos dados no FX4 58
Quadro 40 - Controles identificados no FX4 58
Quadro 41 - Matriz STRIDE do FX4 59
Quadro 42 - Parte A do FX4 Identificação das ameaças 62
Quadro 43 - Parte B do FX4 Priorização e tratamento 63
Quadro 44 - Top 10 por média DREAD e ordem de tratamento 67
Quadro 45 - Distribuição STRIDE por fluxo 67
Quadro 46 - Distribuição por elemento principal do DFD 68
Quadro 47 - Frentes de tratamento e critérios de aceite 69
Quadro 48 - Revisão cruzada por fluxo 71
Quadro 49 - Guias da OWASP por código 75
Quadro 50 - Justificativas de não aplicabilidade nas matrizes 76
Quadro 51 - Extrato histórico de autenticação 77
Quadro 52 - Extrato HTTP do cadastro e do reset 78
Quadro 53 - Trilha documental do FX4 79
Quadro 54 - Reproduções complementares no laboratório (M2) 80

SUMÁRIO

1 INTRODUÇÃO 7
2 FUNDAMENTAÇÃO TEÓRICA 8
3 CONTEXTUALIZAÇÃO DO AMBIENTE 11
4 METODOLOGIA 16
5 MODELO DO SISTEMA 19
6 ANÁLISE DOS FLUXOS 23
    6.1 FX1 LOGIN E USO DA SESSÃO 23
    6.2 FX2 CADASTRO E RECUPERAÇÃO DE SENHA 34
    6.3 FX3 CESTA, CHECKOUT E REGISTRO DO PEDIDO 43
    6.4 FX4 ADMINISTRAÇÃO E CONTABILIDADE 56
7 VISÃO CONSOLIDADA 66
8 VALIDAÇÃO E LIMITAÇÕES 70
9 CONCLUSÃO 72
REFERÊNCIAS 73
APÊNDICE A ARQUIVOS E FONTES DO MODELO 75
APÊNDICE B CAPTURAS E EXTRATOS DE EVIDÊNCIA 77

1 INTRODUÇÃO

Uma falha na autenticação altera as condições sob as quais a loja protege os dados. Na avaliação do Trabalho 1, uma requisição ao login do Juice Shop obteve sessão administrativa sem apresentar a senha correta. Em outro ensaio, o token válido de um cliente permitiu consultar a cesta de outra conta. O primeiro resultado afetou a identidade atribuída à sessão e o segundo mostrou que reconhecer uma sessão não assegura, por si só, a titularidade do recurso. A modelagem parte dessa diferença para determinar onde cada controle precisa atuar (SILVA *et al.*, 2026).

O objetivo geral é identificar e priorizar ameaças em quatro funções da versão v20.2.0 e transformar os cenários de maior risco em requisitos de segurança com critérios de aceite. Para isso, o trabalho descreve a implantação, classifica os dados, representa as fronteiras de confiança e relaciona os achados da M1 às rotas e aos componentes examinados. A questão que orienta a análise é em quais pontos a aplicação aceita uma identidade, um identificador ou uma operação controlada pelo cliente sem verificar a permissão exigida pelo ativo.

O recorte abrange login local e sessão, cadastro e recuperação, cesta e pedido, administração e contabilidade. O ambiente de referência é a implantação local descrita no Compose da M1. O login externo, o chatbot e outros pontos de entrada aparecem na contextualização como parte da superfície conhecida. A exploração, a observação de tráfego e a reprodução de cenários só se aplicam a instâncias de teste autorizadas.

A fundamentação define os critérios usados para modelar e priorizar. A contextualização fixa a versão e os limites do laboratório. Os capítulos seguintes documentam o método, os diagramas e as fichas dos quatro fluxos. A visão consolidada organiza o tratamento, e a validação relaciona evidências, hipóteses e testes pendentes.

2 FUNDAMENTAÇÃO TEÓRICA

2.1 MODELAGEM DE AMEAÇAS NO SSDLC

A modelagem de ameaças identifica condições em que um agente pode comprometer ativos durante o uso previsto de um sistema. No ciclo de vida de desenvolvimento seguro de software, ou Secure Software Development Life Cycle (SSDLC), ela transforma características de projeto em requisitos e casos de verificação. No Secure Software Development Framework (SSDF), Souppaya, Scarfone e Dodson (2022) recomendam, na prática PW.1.1, modelar ameaças e superfícies e considerar relatórios anteriores de vulnerabilidades. Neste estudo, esses relatórios sustentam a análise de pontos do Juice Shop cujo comportamento já foi observado.

Shostack (2014) organiza o trabalho em quatro perguntas. A primeira descreve o sistema construído, a segunda identifica o que pode dar errado, a terceira define o tratamento e a quarta verifica se o modelo e as decisões atendem ao objetivo. Tuma, Çalikli e Scandariato (2018) comparam métodos de análise e identificam limitações na definição de procedimentos e na garantia de qualidade dos resultados. A distinção entre evidência de execução, inspeção de código e hipótese de ataque responde a esse problema no recorte adotado. Ela também indica que tipo de teste pode mudar a conclusão de cada cenário.

2.2 DFD E FRONTEIRAS DE CONFIANÇA

O Diagrama de Fluxo de Dados (DFD) representa entidades externas, processos, armazenamentos e transferências. A entidade fornece ou recebe informações fora do sistema modelado. O processo as transforma e o armazenamento conserva dados, em memória ou em disco. As setas identificam a informação que passa entre elementos. Uma fronteira de confiança marca a mudança nas garantias com que os dados podem ser usados ou nas permissões necessárias para acessá-los (HERNAN *et al.*, 2006).

O nível 0 concentra a aplicação em um processo e explicita suas interfaces externas. O nível 1 mantém essas interfaces e decompõe a operação interna. No laboratório, a separação entre a SPA no navegador e a API no contêiner implica duas verificações distintas. A primeira diz respeito à origem não confiável dos dados. A segunda descreve por onde a rede entrega a requisição. A passagem para SQLite, memória e arquivos marca uma fronteira lógica. Esses recursos compartilham permissões do processo da aplicação.

2.3 STRIDE POR ELEMENTO

STRIDE reúne seis categorias de ameaça, apresentadas no Quadro 1. A classificação orienta o analista a verificar de que modo a autenticidade, a integridade, o não repúdio, a confidencialidade, a disponibilidade ou a autorização podem ser comprometidos (HERNAN *et al.*, 2006). A classificação do cenário descreve a propriedade afetada em primeiro plano. Por exemplo, alterar a consulta SQL do login é adulteração no processo, com uma consequência de elevação de privilégio. A modelagem registra esse mecanismo uma vez para o ranking.

O roteiro aplica S e R a entidades, as seis categorias a processos e T, I e D a fluxos e armazenamentos. A categoria R também se aplica ao armazenamento de logs. Scandariato, Wuyts e Joosen (2015) avaliaram a técnica em termos de produtividade, ameaças incorretas e ameaças omitidas. O preenchimento de uma matriz fornece cobertura de análise. A verificação de uma ameaça depende, além disso, da aderência do cenário à rota, ao papel do agente e à evidência disponível.

Quadro 1 - Categorias STRIDE e propriedades de segurança

Categoria	**Significado**	**Propriedade**
S / Spoofing	Falsificação de identidade	Autenticidade
T / Tampering	Alteração indevida de dados ou lógica	Integridade
R / Repudiation	Contestação de autoria sem evidência suficiente	Não repúdio
I / Information Disclosure	Exposição de informação a agente indevido	Confidencialidade
D / Denial of Service	Indisponibilidade ou degradação da operação	Disponibilidade
E / Elevation of Privilege	Acesso a função ou recurso além da permissão	Autorização

Fonte: adaptado de Hernan *et al.* (2006).

2.4 SUPERFÍCIE DE ATAQUE E PRIORIZAÇÃO

A superfície de ataque compreende os canais, métodos e dados com que um agente consegue interagir. Manadhata e Wing (2011) tratam esses elementos como recursos que contribuem para a exposição de um sistema. No Juice Shop, uma rota, um parâmetro do corpo, um token ou um diretório podem ampliar a superfície por permitir operações diferentes. Uma rota alcançável compõe o inventário. A demonstração de uma falha depende do que o servidor aceita ou devolve por essa rota.

O DREAD organiza a avaliação em potencial de dano, reprodutibilidade, explorabilidade, usuários afetados e facilidade de descoberta (MEIER *et al.*, 2003). Alves *et al.* (2024) aplicam STRIDE e DREAD a um sistema IoT, com identificação e priorização em momentos distintos. Neste estudo, as notas de 1 a 10 expressam julgamento situado no laboratório e seguem a escala do roteiro. A metodologia explicita critérios e desempates. O resultado serve para ordenar a análise e planejar o tratamento. Na M1, a equipe usou CVSS 3.1 para caracterizar a severidade dos achados reproduzidos (SILVA *et al.*, 2026). O NIST (2012) também distingue avaliação de risco de inventário de vulnerabilidades ao considerar condições, impacto e probabilidade.

2.5 REQUISITOS DE SEGURANÇA E DADOS PESSOAIS

O OWASP Application Security Verification Standard (ASVS) fornece requisitos verificáveis para decisões como validar um token ou restringir acesso por objeto. O Common Weakness Enumeration (CWE) descreve tipos de fraqueza. O OWASP Top 10:2021 conserva a classificação histórica usada na M1 (OWASP FOUNDATION, 2021). Os guias da OWASP detalham práticas de implementação (OWASP FOUNDATION, [s. d.]). O registro usa cada referência segundo essa finalidade (MITRE, [s. d.]). Os números de verificação seguem a versão 5.0.0 do ASVS (OWASP FOUNDATION, 2025).

O art. 5º da Lei Geral de Proteção de Dados Pessoais (LGPD) define dado pessoal e estabelece categorias específicas para dados pessoais sensíveis. O princípio da necessidade do art. 6º, III orienta a redução do conteúdo em respostas, tokens e logs. O art. 46 prevê medidas técnicas e administrativas para a proteção contra acesso não autorizado e eventos acidentais ou ilícitos. Carneiro, Kudo e Bulcão Neto (2024) propõem transformar disposições da LGPD em padrões de requisitos de software. Na aplicação modelada, esse vínculo aparece em critérios concretos, como verificar o titular antes de devolver um PDF de pedido e omitir o hash das respostas de recuperação (BRASIL, 2018).

3 CONTEXTUALIZAÇÃO DO AMBIENTE

3.1 IDENTIFICAÇÃO E VERSÃO C1

O OWASP Juice Shop é uma loja fictícia criada para treinamento em segurança de aplicações web. O projeto é mantido por colaboradores da OWASP e reúne desafios deliberados em uma interface de comércio eletrônico. A M1 implantou a imagem oficial bkimminich/juice-shop:v20.2.0. O README da equipe registra o digest abaixo, obtido durante a inspeção inicial da imagem. O Compose fixa a tag e permite conferir o digest em uma nova implantação (OWASP JUICE SHOP, 2026). O registro da equipe conserva o identificador histórico (SILVA *et al.*, 2026).

```
sha256:8739101ade29358abb5469ee66ae78e582c97ed0a5543a4ad102e5fa5193526b
```

3.2 ARQUITETURA E COMUNICAÇÃO C2

A interface é uma aplicação de página única (SPA), construída em Angular e TypeScript. O Node.js executa o servidor Express e fornece operações HTTP em JSON, incluindo recursos gerados por finale-rest e rotas implementadas diretamente. O SQLite é acessado por Sequelize. A configuração normal abre data/juiceshop.sqlite, enquanto o código prevê uma opção em memória. A coleção de pedidos usa MarsDB no processo. A cesta e os registros de conta ficam em SQLite. O comprovante do pedido é um PDF gravado no diretório ftp/ (OWASP JUICE SHOP, 2026).

A autenticação local emite JSON Web Token (JWT) assinado. A SPA o guarda em localStorage e cookie e envia o bearer pelo interceptor, enquanto o servidor mantém um mapa de tokens e usuários autenticados. A presença desse mapa importa para a leitura de cesta e de perfil. Socket.IO atende notificações e funcionalidades do projeto. O código também contém Google OAuth, API de pedidos B2B e chatbot. Essas integrações integram o inventário de entradas, com análise detalhada restrita aos quatro fluxos escolhidos.

3.3 IMPLANTAÇÃO DO LABORATÓRIO C3

Na M1, o host Windows com Docker Desktop executou o contêiner juice-shop na bridge labnet. O Compose publica a porta interna 3000 em 127.0.0.1 na porta configurável JUICESHOP_HTTP_PORT, cujo padrão é 3000. A implantação usa HTTP sem TLS definido no Compose. A rede vulnerable-web-application_labnet e a sub-rede 172.19.0.0/16 constam do registro histórico. O Compose não fixa a sub-rede. A documentação do Docker distingue o endereço publicado no host, o alcance dentro da bridge e as conexões de saída (DOCKER, [s.

d.]). Por isso, o vínculo ao loopback limita a publicação no host e deve ser tratado separadamente do acesso de outros serviços na bridge e da política de saída.

O serviço usa restart: unless-stopped. A verificação HTTP de saúde é feita pelo Node.js em intervalo de 10 segundos, com timeout de 5 segundos, seis falhas consecutivas e período inicial de 20 segundos. O Compose não declara volume, e o servidor inicializa a base com sincronização forçada no código dessa versão. A disponibilidade do histórico depende do ciclo de vida dos armazenamentos e da instância. A análise da implantação é documental e preserva o digest histórico como dado da M1 (SILVA *et al.*, 2026). O Dockerfile da tag indica execução como UID 65532 (OWASP JUICE SHOP, 2026).

3.4 ATORES E PERMISSÕES C4

O Quadro 2 separa o papel esperado na loja dos controles observados em cada rota. O operador do host tem capacidades sobre o ambiente de execução. Os papéis de cliente, administrador e contabilidade são atributos da aplicação. O código aplica controles próprios a rotas de pedidos contábeis, e as guardas Angular definem a navegação do painel (OWASP JUICE SHOP, 2026).

Quadro 2 - Atores e permissões esperadas

Ator ou papel	**Funções e limites**
E1 / visitante	Sem sessão. Usa cadastro, recuperação, login, catálogo e arquivos públicos.
E2 / customer e deluxe	Opera a própria cesta e pedidos. Deluxe tem benefícios condicionados ao papel e ao token de associação.
E3 / admin	Consulta usuários e modera feedbacks pela interface prevista. A análise verifica a permissão na API separadamente.
E4 / accounting	Consulta pedidos e modifica entrega em rotas com verificação de papel. A alteração de estoque, fora do recorte detalhado, também usa filtro de IP no servidor.
Operador do host	Gerencia rede, processo, contêiner e arquivos. Sua integridade é premissa do laboratório.
Serviços externos	Google OAuth e API de modelo para chatbot aparecem em configuração. O Compose não provisiona esses serviços.

Fonte: OWASP Juice Shop (2026) e Silva *et al.* (2026).

3.5 ATIVOS E CLASSIFICAÇÃO DE DADOS C5

Os ativos que sustentam as quatro funções incluem contas, credenciais, sessão, cesta, pedido e comprovante. O quadro identifica os dados que seriam pessoais quando se referissem a pessoa natural identificada ou identificável. Os registros examinados foram de teste ou

demonstração. O art. 5º, II, da LGPD reserva a classe sensível a categorias determinadas, entre elas saúde, origem racial ou étnica e biometria vinculada à pessoa. Senha, token e cartão exigem proteção pelo risco e pela finalidade. Esses campos, em si, não se enquadram nas categorias legais sensíveis (BRASIL, 2018).

Quadro 3 - Ativos e classificação de dados

Conjunto de dados	**Conteúdo**	**Classificação**
Identificação e contato	E-mail, nome, endereço, telefone, IP quando vinculável.	Dados pessoais quando se referem a titular identificável.
Credenciais e sessão	Senhas, hashes, resposta de segurança, JWT e segredo TOTP quando configurado.	Segredos de autenticação. Alguns também se vinculam ao titular.
Cesta e pedido	Itens, valores, endereço, estado de entrega e comprovante.	Dados pessoais quando associados à conta. A operação exige integridade.
Cartão e carteira	Número, nome, validade e saldo na simulação.	Dados de pagamento. Cartões do laboratório são fictícios.
Catálogo, feedback e arquivos	Preços públicos, conteúdo de avaliação e documentos de demonstração.	A classificação depende da finalidade, do vínculo pessoal e do conteúdo.
Disponibilidade e trilha	Capacidade de atender login, compra e operações privilegiadas. Registros de acesso.	Ativos operacionais. Os registros podem conter dados pessoais.

Fonte: Brasil (2018), OWASP Juice Shop (2026) e Silva *et al.* (2026).

3.6 PONTOS DE ENTRADA C6

A superfície do laboratório inclui HTTP, a SPA, APIs e arquivos. As interfaces administrativas compartilham a porta do serviço. O fragmento de URL usado pelo Angular seleciona uma tela no navegador e a tela faz requisições HTTP distintas à API. As entradas evidenciadas na M1 e as interfaces localizadas somente no código estão diferenciadas no Quadro 4 (SILVA *et al.*, 2026). O inventário considera canais e dados no sentido de Manadhata e Wing (2011) e da orientação da OWASP (OWASP FOUNDATION, [s. d.]).

Quadro 4 - Superfície de ataque por categoria

Categoria	**Entradas e evidência**
Rede	HTTP TCP 3000 em loopback e serviço na bridge. Socket.IO integra o servidor. TB-01 e TB-02.
Interface de usuário	Login, cadastro, recuperação, busca, itens, checkout. F09 a F14. A M1 registra login, reset e leitura de cesta.
Administrativa	/#/administration, /#/accounting e respectivas APIs. F15 e F16. /metrics existe no código e fica fora dos quatro recortes.

Categoria	Entradas e evidência
Integração externa	Google OAuth e proxy auxiliar, /b2b/v2/orders, /rest/chat e URL local de API de modelo. Código e configuração, sem uso comprovado na M1.
Dados e arquivos	Corpos JSON, parâmetros, cookies, JWT, SQLite e PDFs. /file-upload consta do código. /ftp/ é caminho HTTP e a M1 comprovou sua listagem em V5.

Fonte: OWASP Juice Shop (2026) e Silva *et al.* (2026).

3.7 DEPENDÊNCIAS RELEVANTES C7

O Quadro 5 relaciona as dependências declaradas nos manifests da tag v20.2.0 e seu papel na análise. O circunflexo indica a faixa declarada. A versão resolvida na imagem da M1 depende de inspeção da imagem. O relatório usa o comportamento e as evidências da rota para caracterizar fraquezas. A presença de uma dependência, por si só, não constitui diagnóstico de CVE.

Quadro 5 - Dependências e funções de segurança

Componente	Versão declarada	Relevância
Angular	^22.0.1	Interface e guardas de navegação. Chamadas diretas continuam sujeitas à API.
Express e finale-rest	^4.22.1 e ^1.2.2	Middlewares e CRUD. A autorização depende da rota e da configuração do recurso.
Sequelize e sqlite3	^6.37.3 e ^5.1.7	Persistência local. A consulta bruta de login não usa a proteção de parâmetros do ORM.
jsonwebtoken e express-jwt	0.4.0 e 0.1.3	Emissão e validação de JWT. Opções e claims precisam ser coerentes com a implementação usada.
express-rate-limit	^7.5.1	Cota de reset. A chave de IP e a confiança no proxy afetam o controle.
MarsDB e Socket.IO	^0.6.11 e ^3.1.2	Coleções em memória e comunicação em tempo real, respectivamente.
Morgan, serve-index e PDFKit	Manifests da tag	Registro HTTP, listagem de arquivos e geração de comprovantes.

Fonte: manifests da tag v20.2.0, em OWASP Juice Shop (2026).

3.8 INVENTÁRIO E SELEÇÃO DE FLUXOS C8

Foram identificadas cinco funcionalidades candidatas. O Quadro 6 registra os quatro recortes analisados e um fluxo de reserva. A seleção cobre sessão em FX1, dados pessoais em FX2 e FX3 e ações privilegiadas em FX4. Todos os fluxos selecionados atravessam a interface cliente-servidor e chegam a pelo menos um armazenamento. Três contêm evidência do Trabalho 1.

Quadro 6 - Fluxos candidatos e critérios de seleção

ID	Funcionalidade	Seleção	Justificativa
FX1	Login e uso da sessão	Selecionado	F09 e F10. Sustenta a identidade das demais funções. V1, V2 e V6.
FX2	Cadastro e recuperação de senha	Selecionado	F11 e F12. Grava dados de conta e expõe mecanismo de recuperação. V7.
FX3	Cesta, checkout e pedido	Selecionado	F13, F14, F17 e F18. Trata dados de compra e comprovante. V3 e V4. V5 apoia análise de arquivos.
FX4	Administração e contabilidade	Selecionado	F15 e F16. Permissões de função e de acesso a dados de vários titulares.
FX5	Login com Google OAuth	Reserva	Depende de provedor e redirecionamento externo. O Compose do laboratório não comprova sua operação.

Fonte: OWASP Juice Shop (2026) e Silva *et al.* (2026).

3.9 PREMISSAS E DELIMITAÇÃO C9

O agente modelado é uma pessoa com acesso ao laboratório, com ou sem conta, ou um operador de papel definido. A capacidade de controlar o próprio cliente e a entrada da API faz parte do cenário. O host, o motor do Docker e o ambiente de rede local são assumidos íntegros. A possibilidade de roubo ou reuso de token é avaliada com a obtenção da credencial como precondição. O modelo não mede ataques de rede volumétricos, comprometimento do host, segurança física, terceiros externos, infraestrutura de nuvem ou a totalidade dos desafios da plataforma.

O código de Google OAuth, chatbot, B2B, métricas e upload ajuda a delimitar a superfície. O recorte detalhado não depende de credenciais de terceiro, de dados reais de cartão ou de transações externas. Os testes de carga, exploração de hipóteses e validação das mitigações propostas requerem execução própria em instância controlada.

3.10 RELAÇÃO COM OS ACHADOS DO TRABALHO 1 C10

O Quadro 7 vincula os sete achados históricos ao DFD e ao registro. A pontuação CVSS 3.1 vem da M1 e mantém a classificação histórica. V4 ocorreu no tratamento do cabeçalho em uma rota de cesta. V5 comprova a exposição do diretório e de documento de exemplo, sustentando uma hipótese distinta sobre PDFs de pedido. Os registros de V7 mostram sucesso no quinto palpite e a cota informada de 100 solicitações. A evidência não caracteriza tentativas ilimitadas. Injeção NoSQL, XSS e upload inseguro não figuram entre V1 e V7 no repositório da M1.

Quadro 7 - Rastreabilidade dos achados da M1

ID	OWASP e CVSS 3.1	Efeito observado	Localização e registro na M2
V1	A03 / 9,1	SQL injection em POST /rest/user/login e entrada como admin.	FX1 / P2, F09, F21 e D1. T-FX1-02
V2	A02 / 6,5	Hash MD5 no payload de JWT de conta própria. Encadeado com V1, a M1 registrou 7,5.	FX1 / P2, F10, D0 e D2. T-FX1-04
V3	A01 / 6,5	Consulta da cesta da conta A com JWT válido da conta B. Sem token, o acesso foi recusado.	FX3 / P4, F13, F14, F27 e D1. T-FX3-06
V4	A05 / 5,3	Erro detalhado com Authorization malformado na rota de cesta. A resposta inicial examinada não continha CSP ou HSTS.	FX3 / P4, F13 e F14. T-FX3-04
V5	A05 / 7,5	Listagem e download anônimos em /ftp/ para documento de exemplo.	P6, F17, F18 e D4. Evidência para o canal de exposição do FX3.. Apoia T-FX3-07, que examina PDF de pedido.
V6	A07 / 6,5	Quinze falhas HTTP 401 em sequência, seguidas de login correto HTTP 200, sem bloqueio observado nessa amostra.	FX1 / P2 e F09. T-FX1-01
V7	A04 / 9,1	Consulta da pergunta associada e redefinição no quinto palpite, dentro da cota de 100 indicada pela resposta.	FX2 / P3, F11, F12 e D1. T-FX2-01 e T-FX2-04

Fonte: Silva *et al.* (2026) e elaboração própria.

4 METODOLOGIA

4.1 ETAPAS E FONTES DE EVIDÊNCIA

A análise documental começou pelo Compose, pelo relatório e pelos artefatos da M1. O código e os testes upstream foram fixados na tag v20.2.0, com identificação dos commits no Apêndice A. Os registros históricos foram consultados para recuperar método, rota, status, conteúdo relevante e precondições dos ensaios. A validação de dados do modelo e o cálculo das médias foram feitos em Python. Os diagramas foram exportados para SVG e para um arquivo editável do diagrams.net. A reconstrução da arquitetura considerou rotas, modelos, serviços Angular, middlewares e arquivos de configuração.

O estado Confirmada no T1 é reservado ao comportamento observado em requisição, resposta ou captura histórica da equipe. Um achado pode sustentar mais de um cenário quando a evidência mostra efeitos distintos, como consulta da pergunta e tomada de conta em V7. Plausível identifica hipótese fundamentada em código, documentação, teste upstream ou

mecanismo conhecido, sem reprodução pela equipe. O estado Tratada por controle existente se aplicaria quando houvesse evidência de que o controle cobre o cenário. Os controles que cobrem apenas uma variante, como a unicidade da resposta de segurança, permanecem documentados como limites da hipótese.

4.2 CONVENÇÕES E APLICAÇÃO DO STRIDE

Os identificadores E, P, D, F e TB designam entidades, processos, armazenamentos, setas e fronteiras. Um identificador FX representa uma funcionalidade composta por várias setas F. As tabelas de percurso indicam as transferências que o recorte cobre, sem converter o DFD em uma sequência obrigatória de execução. Os identificadores T-FX<n>-<nn> identificam cenários e ligam a ficha, a matriz, o questionário e o registro. A primeira referência de cada ameaça indica o elemento principal usado na contagem consolidada.

A matriz contém uma linha para cada elemento e seta do recorte. O ID em uma célula indica a ameaça associada à propriedade examinada. As células com N/A remetem a justificativas de escopo ou aplicabilidade. Células vazias indicam que a categoria não se aplica ao tipo segundo a matriz do roteiro. Um cenário mantém uma categoria principal mesmo quando produz efeitos adicionais. As perguntas Q1 a Q7, S1 a E3 e V1 a V3 são respondidas em cada fluxo. Os V do questionário de fechamento pertencem ao formulário. Quando o texto menciona um achado da M1, identifica-o como tal.

4.3 CRITÉRIOS DE PONTUAÇÃO DREAD

A média de cada cenário usa as cinco notas com pesos iguais. O cálculo soma dano, reprodutibilidade, explorabilidade, usuários afetados e descoberta, e divide o total por cinco. O Quadro 8 indica âncoras de julgamento comuns aos quatro fluxos. A escala efetiva vai de 1 a 10. Conforme o roteiro, resultados de 0 a 3,9 são classificados como baixos, de 4,0 a 6,9 como médios e de 7,0 a 10 como altos. Um valor zero não ocorre com a regra de notas adotada.

A média é exibida com uma casa decimal. O ranking usa a soma exata, equivalente à média para cinco notas inteiras. Empates são resolvidos pela confirmação histórica, pelo dano e, por fim, pelo ID. A ordem resulta de uma avaliação relativa no ambiente acadêmico. Mudanças de precondição, volume de dados, exposição ou evidência justificam revisar as notas. Os cenários foram pontuados na condição atual do laboratório. O risco residual após os

controles foi descrito em termos qualitativos, pois os controles ainda exigem implantação e verificação.

Quadro 8 - Âncoras para atribuição das notas DREAD

Dimensão	**1 a 3**	**4 a 6**	**7 a 10**
Dano	Impacto pontual, sem comprometimento de ativo relevante.	Dado ou operação de uma conta afetados, com possibilidade de correção.	Tomada de conta, ação privilegiada, perda ampla ou degradação relevante.
Reprodutibilidade	Exige condições raras e difíceis de manter.	Depende de estado específico, concorrência ou configuração.	A mesma sequência tende a produzir efeito em condição conhecida.
Explorabilidade	Exige acesso especial, material raro ou técnica avançada.	Exige uma conta, estado alvo ou algum conhecimento da API.	Rota alcançável e ação simples com ferramentas comuns.
Usuários afetados	Um evento isolado ou um recurso de uso restrito.	Parte dos titulares ou várias ocorrências de uma conta.	Vários titulares, uma classe de papéis ou a instância compartilhada.
Descoberta	Ponto obscuro com pouca observabilidade.	Inspeção da rota, do código ou dos registros.	Superfície pública ou campo evidente no contrato ou nas respostas.

Fonte: elaboração própria, com base em Meier *et al.* (2003) e no roteiro da disciplina.

4.4 DIVISÃO DO TRABALHO E TRATAMENTO

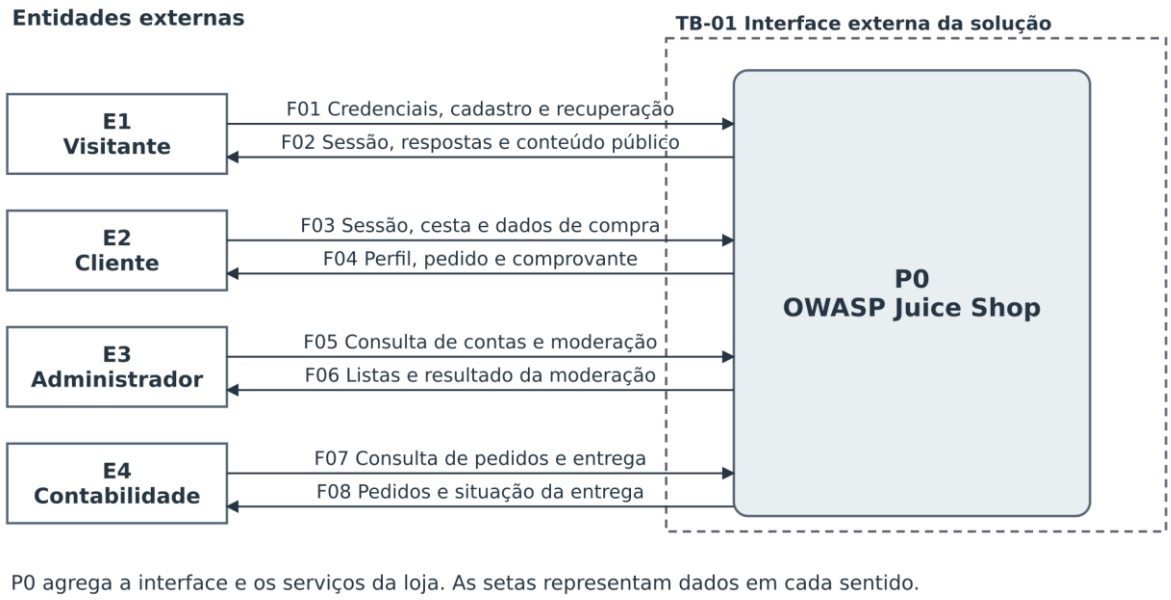
O quadro de participação reúne as contribuições registradas e propõe uma divisão para a revisão final. Cada ameaça recebeu uma decisão, um tipo de controle, uma camada e um critério de aceite. O tratamento mantém a função de negócio e altera a implementação que gera exposição.

5 MODELO DO SISTEMA

5.1 DFD DE CONTEXTO

A Figura 1 concentra o recorte em P0. As entidades são atores humanos externos ao sistema lógico. A interface mais próxima de cada ator se mantém na Figura 2, que detalha a SPA em P1, executada sob controle do navegador. O operador do Docker aparece no contexto do laboratório. Seus comandos de gestão e integrações fora dos quatro fluxos não são setas do DFD.

Figura 1 - DFD de contexto do OWASP Juice Shop

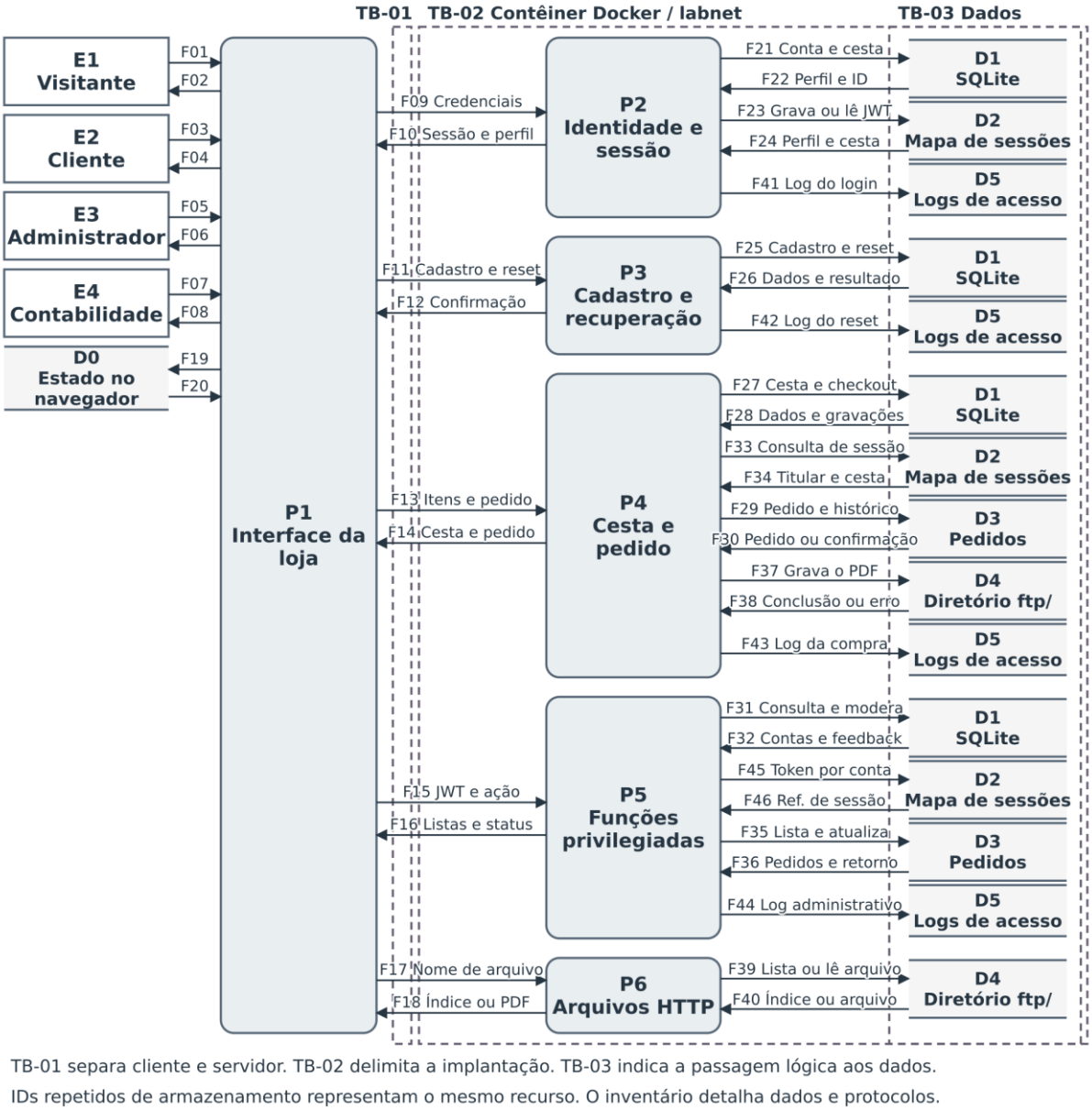


Fonte: elaboração própria.

5.2 DFD DE NÍVEL 1

No nível 1, P2 a P6 representam responsabilidades do mesmo serviço Express. SQLite, mapa de sessões, pedidos, arquivos e logs aparecem como armazenamentos distintos. A duplicação visual de D1, D2, D3, D4 e D5 facilita a leitura e conserva o mesmo ID para o mesmo recurso. As setas F01 a F08 preservam as interfaces de P0. As demais setas detalham a transferência entre interface, API e armazenamento.

Figura 2 - DFD detalhado e fronteiras de confiança



TB-01 separa cliente e servidor. TB-02 delimita a implantação. TB-03 indica a passagem lógica aos dados. IDs repetidos de armazenamento representam o mesmo recurso. O inventário detalha dados e protocolos.

Fonte: elaboração própria.

5.3 INVENTÁRIO DE ELEMENTOS E FRONTEIRAS

Quadro 9 - Inventário dos elementos do DFD

ID	Tipo	Responsabilidade	Tecnologia
P0	Processo	OWASP Juice Shop. Aplicação de loja fictícia vista como processo único no nível 0.	Angular e Node.js/Express
E1	Entidade externa	Visitante. Pessoa sem sessão. Inicia cadastro, recuperação e login, e consulta conteúdo público.	Navegador ou cliente HTTP
E2	Entidade externa	Cliente. Titular de conta customer ou deluxe com sessão. Opera a própria cesta e compra.	Navegador ou cliente HTTP
E3	Entidade externa	Administrador. Papel admin previsto para consulta de contas e moderação de feedbacks.	Navegador ou cliente HTTP
E4	Entidade externa	Contabilidade. Papel accounting previsto para consultar pedidos e modificar o estado de entrega.	Navegador ou cliente HTTP
P1	Processo	Interface da loja. Executa no navegador, monta requisições e apresenta respostas. Chamadas diretas podem substituir a SPA.	Angular 22 e cliente HTTP
P2	Processo	Identidade e sessão. Consulta conta e cesta, emite JWT e recupera a identidade da sessão.	Express, Sequelize, jsonwebtoken
P3	Processo	Cadastro e recuperação. Cria conta, associa pergunta e resposta de segurança e troca a senha.	Express, finale-rest, Sequelize
P4	Processo	Cesta e pedido. Administra itens, endereços e cartões fictícios, calcula pedido e gera comprovante.	Express, Sequelize, MarsDB, PDFKit
P5	Processo	Funções privilegiadas. Executa operações administrativas e de contabilidade, com guardas diferentes por rota.	Express, finale-rest, MarsDB
P6	Processo	Arquivos HTTP. Lista e entrega arquivos de ftp/, inclusive comprovantes quando presentes.	serve-index, Express sendFile
D0	Armazenamento	Estado no navegador. Mantém token no localStorage e em cookie, além do ID de cesta no sessionStorage.	Web Storage e cookie
D1	Armazenamento	SQLite. Guarda contas, respostas de segurança, cestas, endereços, cartões, estoque e feedbacks.	SQLite, arquivo data/juiceshop.sqlite
D2	Armazenamento	Mapa de sessões. Associa JWT, perfil autenticado e identificador de cesta. Também pode ser repovoado por middleware.	Mapa autenticado em memória Node.js
D3	Armazenamento	Pedidos. Guarda coleção de pedidos e estado de entrega em memória.	MarsDB, coleção orders
D4	Armazenamento	Diretório ftp/. Contém documentos de exemplo e PDFs gravados no checkout.	Sistema de arquivos do contêiner

ID	Tipo	Responsabilidade	Tecnologia
D5	Armazenamento	Logs de acesso. Recebe registros HTTP em formato combined com rotação diária e retenção configurada de dois dias.	Morgan, file-stream-rotator, logs/access.log.*

Fonte: OWASP Juice Shop (2026) e elaboração própria.

A separação lógica em TB-03 não cria uma conexão de banco pela rede nem uma conta de serviço por módulo. A confiabilidade da resposta depende do filtro e da autorização aplicados no processo antes da consulta. De modo semelhante, TB-01 e TB-02 descrevem propriedades diferentes da mesma passagem de rede. A validação de entrada pertence ao servidor, e o isolamento de rede pertence à implantação. A SPA e seu armazenamento permanecem do lado cliente.

Quadro 10 - Fronteiras de confiança

ID	Lados da fronteira	Mudança de confiança	Transferências
TB-01	Cliente | servidor	Os dados controlados pelo cliente chegam a rotas que devem autenticar, autorizar e validar. No contexto, a fronteira aparece condensada na interface do sistema.	F09 a F18 no nível 1. F01 a F08 representam a interface externa no nível 0.
TB-02	Host | contêiner na bridge labnet	O encaminhamento da porta do host chega ao processo do contêiner. Loopback restringe a publicação no host. Outros serviços da mesma bridge e saída de rede são questões distintas.	F09 a F18 no percurso de rede. A passagem coincide com TB-01, sob outra perspectiva.
TB-03	Lógica de aplicação | armazenamentos	A operação passa de requisição a leitura ou gravação de ativos internos. SQLite e MarsDB são locais. A fronteira expressa uma distinção lógica, com permissões de processo e de arquivo.	F21 a F46. D0 pertence ao cliente e fica fora desta fronteira.

Fonte: elaboração própria.

5.4 SUPERFÍCIE DE ATAQUE DO MODELO

O Quadro 4 reúne pontos de entrada do laboratório. No modelo, P2 e P3 recebem entradas públicas de identidade, P4 opera dados vinculados a cliente, P5 concentra funções privilegiadas e P6 dá acesso a arquivos. O Quadro 11 associa as entradas a processos e setas. O Quadro 10 indica as fronteiras correspondentes. Cada ficha de fluxo detalha as setas, os dados e os formatos empregados.

Quadro 11 - Entradas do recorte e elementos afetados

Canal	Processos e setas	Dados controlados
Identidade e recuperação	P2 e P3. F09 a F12.	Senha, e-mail, token, pergunta, ID e papel no cadastro.
Compra e consulta	P4. F13 e F14.	JWT, IDs, quantidade, endereço, cartão sintético e campos de pedido.
Administração e contabilidade	P5. F15 e F16.	JWT, identificadores, comandos de moderação e status de entrega.
Arquivos HTTP	P6. F17 e F18.	Nome de documento, listagem e resposta com bytes do arquivo.

Fonte: elaboração própria.

6 ANÁLISE DOS FLUXOS

A análise aplica a ficha, a matriz STRIDE, o questionário e o registro a quatro funções. Em cada caso, a primeira referência identifica o principal elemento afetado. As fontes de execução e as hipóteses de código aparecem separadas.

6.1 FX1 LOGIN E USO DA SESSÃO

Após enviar e-mail e senha, o cliente recebe uma sessão de compra se a autenticação for bem-sucedida. A SPA armazena o token e o ID de cesta e reutiliza a credencial para identificar a conta e operar as rotas protegidas. O fluxo inclui consulta do perfil e limpeza local de sessão.

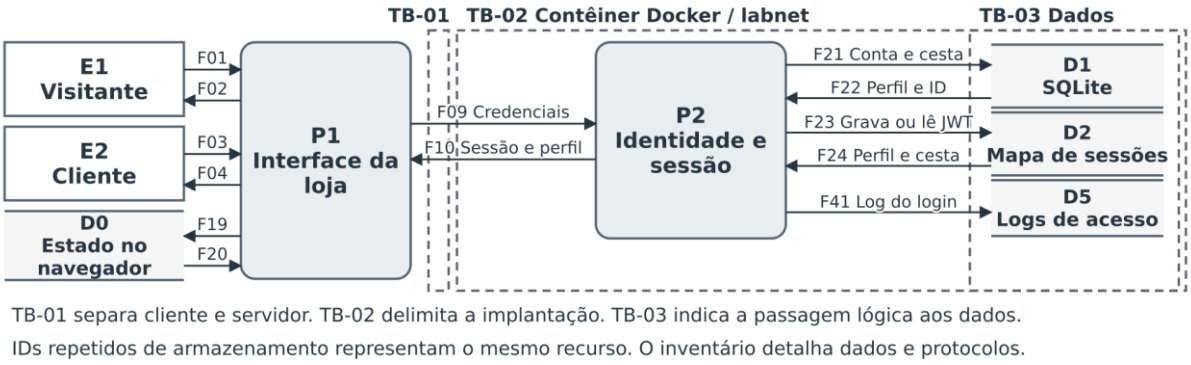
6.1.1 Ficha do fluxo

Quadro 12 - Identificação e condições do FX1

Campo	Descrição
ID e função	FX1 / Login e uso da sessão
Responsável e revisor propostos	Diego Fonseca da Silva / Gustavo Gonçalves Trindade
Ator e gatilho	Visitante E1 ao enviar o formulário de login. O cliente E2 atua depois da emissão.
Pré-condições	Conta cadastrada, aplicação acessível e credenciais válidas. O código prevê TOTP quando configurado. O desafio de segundo fator fica fora do recorte principal.
Resultado esperado	Token para a conta autenticada, ID de cesta associado e perfil nas chamadas de sessão. Logout remove o estado do navegador.

Fonte: elaboração própria.

Figura 3 - Recorte do DFD do FX1



Fonte: elaboração própria.

Quadro 13 - Requisições e evidências do FX1

Método e rota	**Base**	**Observação**
POST /rest/user/login	M1 V1, V2 e V6	Requisição de login, emissão e série de falhas. Figuras 7 e 8 e extrato A1.
GET /rest/user/whoami	Código v20.2.0	routes/currentUser.ts. Cookie token e parâmetro fields.
GET /rest/basket/:id	M1 V3, chamada protegida de apoio	Requisição sem token recusada e com token válida para acesso. O objeto é analisado no FX3.

Fonte: OWASP Juice Shop (2026), Silva *et al.* (2026) e elaboração própria.

Quadro 14 - Elementos percorridos no FX1

Nº	**De**	**Para**	**Seta**	**Dados trafegados**	**Protocolo e formato**	**Fronteira**
1	E1	P1	F01	Credenciais, cadastro, recuperação, navegação e arquivos públicos	Interface web / formulário	Sem travessia
2	P1	E1	F02	Formulários, identidade inicial e respostas públicas	Interface web / renderização	Sem travessia
3	E2	P1	F03	Ações autenticadas de sessão, cesta e compra	Interface web / formulário	Sem travessia
4	P1	E2	F04	Perfil, itens, estado de compra e comprovante	Interface web / renderização	Sem travessia
5	P1	P2	F09	E-mail e senha, cookie ou JWT Bearer	HTTP / JSON	TB-01 TB-02
6	P2	P1	F10	JWT, ID de cesta, perfil e erros	HTTP / JSON	TB-01 TB-02
7	P1	D0	F19	JWT, cookie e ID da cesta	Web Storage / cookie	Sem travessia

Nº	De	Para	Seta	Dados trafegados	Protocolo e formato	Fronteira
8	D0	P1	F20	JWT e ID da cesta para requisições	Web Storage / cookie	Sem travessia
9	P2	D1	F21	Consulta de credenciais e busca ou criação da cesta	Sequelize / SQL local	TB-03
10	D1	P2	F22	Modelo da conta e ID da cesta	Sequelize / SQL local	TB-03
11	P2	D2	F23	Gravação ou consulta por JWT	Acesso em memória	TB-03
12	D2	P2	F24	Perfil, ID da cesta ou ausência de sessão	Acesso em memória	TB-03
13	P2	D5	F41	Método, URL, horário, origem e status de autenticação HTTP	Escrita local / log HTTP	TB-03

Fonte: elaboração própria.

Quadro 15 - Classificação dos dados no FX1

Dado	Classificação	Localização	CID crítica
E-mail, ID e IP de acesso	Dado pessoal quando identificável	F09, F10, F21, F22, D1 e D5	Confidencialidade
Senha e hash MD5	Credencial ou segredo	Senha em F09, hash em D1 e observado em F10	Confidencialidade
JWT e cookie token	Credencial de sessão	F09, F10, F19, F20, D0 e D2	Confidencialidade
Papel e vínculo de cesta	Interno e dado pessoal vinculado	D1, D2, F10 e D0	Integridade

Fonte: Brasil (2018), OWASP Juice Shop (2026) e elaboração própria.

Quadro 16 - Controles identificados no FX1

Controle	Elemento	Base de constatação
Assinatura RS256 em emissão e verificação em rotas protegidas	P2, F09 e F10	Código e JWT preservado em V1 e V2.
Resposta inválida HTTP 401 e TOTP condicional	P2	V6 e routes/login.ts. O segundo fator não foi exercitado na M1.
Hash de senha e filtro de conta excluída	P2, D1	routes/login.ts, models/user.ts e V2. O hash é MD5 sem sal.
Registro HTTP com rotação	D5, F41	server.ts. Evidência de configuração, sem verificação de proteção do arquivo.

Fonte: OWASP Juice Shop (2026) e Silva *et al.* (2026).

6.1.2 Matriz STRIDE por elemento

Os códigos NA1 a NA13 remetem às justificativas do Apêndice A. Cada célula preenchida vincula uma ameaça do FX1 ou registra N/A para a categoria aplicável ao tipo. O detalhamento das setas consta do quadro de percurso.

Quadro 17 - Matriz STRIDE do FX1

Elemento	S	T	R	I	D	E
D0 Estado no navegador		N/A 11		T-FX1-04	N/A 10	
D1 SQLite		N/A 7		N/A 7	N/A 6	
D2 Mapa de sessões		N/A 7		T-FX1-04	T-FX1-05	
D5 Logs de acesso		N/A 9	T-FX1-03	N/A 9	N/A 9	
E1 Visitante	T-FX1-01		T-FX1-03			
E2 Cliente	N/A 1		T-FX1-03			
P1 Interface da loja	N/A 8	N/A 13	N/A 8	T-FX1-04	N/A 10	N/A 8
P2 Identidade e sessão	T-FX1-01	T-FX1-02	T-FX1-03	T-FX1-04	T-FX1-05	T-FX1-06
F01		N/A 13		N/A 13	N/A 6	
F02		N/A 13		N/A 13	N/A 6	
F03		N/A 13		N/A 13	N/A 6	
F04		N/A 13		N/A 13	N/A 6	
F09		T-FX1-02		N/A 4	T-FX1-05	
F10		N/A 3		T-FX1-04	N/A 6	
F19		N/A 11		T-FX1-04	N/A 6	
F20		N/A 11		T-FX1-04	N/A 6	
F21		T-FX1-02		N/A 4	N/A 6	
F22		N/A 3		N/A 4	N/A 6	
F23		N/A 3		N/A 4	T-FX1-05	
F24		N/A 3		N/A 4	N/A 6	
F41		N/A 9		N/A 9	N/A 6	

Fonte: elaboração própria.

6.1.3 Questionário do fluxo

Compreensão do fluxo

Q1 FX1 vincula uma identidade a uma sessão que sustenta compras e operações privilegiadas. Uma falha em P2 pode ampliar o alcance das demais ameaças, como ocorreu na passagem a admin em T-FX1-02.

Q2 E1 fornece credenciais. Com sessão emitida, E2 usa os serviços da conta. Os papéis de admin e accounting compartilham a entrada de login e têm funções específicas modeladas em FX4.

Q3 F01 chega a P1 pela interface. F09 transporta JSON para P2, que consulta D1 via F21 e F22 e usa o mapa D2 via F23 e F24. F10 devolve a sessão. F19 e F20 tratam Web Storage e cookie, e F41 grava metadados HTTP.

Q4 F09 e F10 cruzam TB-01 e TB-02 quando o navegador chega ao processo na porta publicada. F21 a F24 e F41 cruzam TB-03. Em D1 a entrada ganha efeito sobre consulta, de modo que o e-mail precisa entrar como parâmetro.

Q5 E-mail, ID e IP vinculável são pessoais. Senha, hash e JWT são segredos. D1 guarda o hash e D0 e D2 guardam estado de sessão. Os campos examinados não integram as categorias sensíveis do art. 5º, II da LGPD.

Q6 Corpo JSON de login, header Authorization, cookie token e parâmetro fields de whoami entram pela interface ou pela API. localStorage e sessionStorage compõem a superfície de dados do navegador.

Q7 V6 mostra rejeição de senha incorreta. A M1 confirma JWT assinado e hash MD5. O código identifica verificação de assinatura, TOTP condicional, mapa de sessão e log HTTP. O Compose usa HTTP de loopback.

Spoofing

S1 P2 compara o valor da senha com D1. As rotas protegidas usam JWT e whoami usa cookie e mapa. SQLite é biblioteca local, acessada pelo processo, sem login de banco pela rede.

S2 P2 emite JWT RS256. A SPA o guarda em localStorage e em cookie com prazo de oito horas e o interceptor usa Bearer. O código fornece expiresIn à biblioteca 0.4.0, cuja opção é expiresInMinutes. Os JWTs de V1 e V2 não têm exp. A inspeção do logout mostra remoção local, sem operação de revogação identificada no percurso. Novo login emite novo token.

S3 T-FX1-01 explora tentativas sem contenção efetiva na amostra. T-FX1-06 examina o efeito potencial da chave fixa sobre papéis reservados. A M1 confirmou ainda um login administrativo sem senha correta por injeção.

Tampering

T1 O e-mail pode ser modificado antes de F09 e alterar o SQL em F21. P1 e D0 estão sob controle do cliente. Manipular arquivo SQLite diretamente requer condição de host excluída do recorte.

T2 P2 calcula hash da senha e verifica conta ativa no sentido de não excluída pela consulta. O e-mail ainda compõe o SQL por interpolação, como demonstrou V1. A autorização de objeto deve ocorrer nas rotas consumidoras.

T3 RS256 protege a integridade do JWT quando a assinatura é validada com chave confiável. O transporte em loopback usa HTTP. O MD5 de senha não protege o fluxo nem corrige a interpolação.

Repudiation

R1 F41 grava método, URL, data, status, origem e agente de usuário. A inspeção de Morgan combined não identificou ID da conta e da sessão no mesmo evento de autenticação.

R2 D5 é local, com rotação diária e retenção configurada de dois dias. O modelo não encontrou coleta separada ou imutabilidade para F41.

R3 Sim. Uma autenticação ou tentativa pode ser negada quando só se dispõe da origem aparente, sem ligação com uma sessão e o resultado do controle. O cenário está em T-FX1-03.

Information Disclosure

I1 O JWT de F10 inclui hash e perfil, observado em V2. whoami atende a lista de fields sem uma lista de permissão identificada no código, que também possui teste upstream para o campo password.

I2 P1 precisa do identificador, do estado de autenticação e de informações de interface. Serializar o modelo da conta transfere dados que não são necessários à sessão, como password.

I3 HTTP local não fornece TLS. O hash fica em SQLite, o token assinado é legível pelo portador e a SPA o guarda em D0. Não houve evidência de criptografia de arquivo nem de gestão isolada da chave de demonstração.

Denial of Service

D1 Login consome consultas de conta e cesta, CPU e memória para emissão e mapa D2. O efeito por volume em T-FX1-05 não foi medido.

D2 O parser tem limite geral por corpo. As quinze falhas de V6 não encontraram bloqueio e o caminho de login analisado não definiu limitador próprio. Limite de mapa e expurgo não foram identificados.

D3 Login local depende de SQLite, do processo Node.js e dos arquivos de configuração. O recorte de e-mail e senha não depende de Google nem de provedor externo.

Elevation of Privilege

E1 P2 autentica. A rota protegida deve validar o token e aplicar a permissão do recurso. A prova de assinatura isolada não decide papel, objeto ou campo permitido.

E2 V1 obteve papel administrativo pelo login. T-FX1-06 considera tokens forjados com a chave distribuída. FX3 e FX4 discriminam os recursos que aplicam verificações distintas.

E3 O Dockerfile da versão define UID 65532. SQLite e mapa pertencem ao processo Node.js. A modelagem não verificou privilégios efetivos por inspeção de contêiner.

Fechamento do fluxo

V1 T-FX1-02 tem média 9,8 e prevalece porque a entrada anônima pode levar à identidade administrativa, com efeitos sobre dados e funções de outros titulares.

V2 A M1 confirmou T-FX1-02 por V1, T-FX1-04 por V2 e a sequência de T-FX1-01 por V6. Esgotamento, atribuição incompleta e uso de chave em ataque ficam como hipóteses documentais.

V3 O recorte usa login local por senha. Verificação temporal rota a rota, recuperação com TOTP e comportamento após logout requerem ensaio separado em instância controlada.

6.1.4 Registro de ameaças

Quadro 18 - Parte A do FX1 Identificação das ameaças

ID e elementos principais	STRIDE e propriedade	Cenário	CWE e OWASP 2021	Status
T-FX1-01 P2, E1	S / Autenticidade	Um visitante E1 pode repetir palpites de senha em P2 pelo fluxo F09, explorando a ausência de contenção efetiva na sequência observada. Se acertar uma senha fraca, passa a se apresentar como o titular da conta.	CWE-307 A07	Confirmada no T1 (V6)

ID e elementos principais	STRIDE e propriedade	Cenário	CWE e OWASP 2021	Status
T-FX1-02 P2, F09, F21	T / Integridade	Um visitante E1 pode alterar a lógica da consulta de autenticação em P2 e F21 enviando entrada controlada em F09. A concatenação do e-mail ao SQL permite ignorar o predicado de senha e iniciar uma sessão administrativa, com acesso a dados e ações reservadas.	CWE-89 A03	Confirmada no T1 (V1)
T-FX1-03 D5, P2, E1	R / Não repúdio	Um agente que obtenha uma sessão em P2 pode negar a autoria da autenticação ou atribuí-la a outra pessoa. Em F41 e D5, o log de acesso com origem e horário permite ver a chamada, mas não associa de forma inequívoca tentativa, conta, sessão e resultado.	CWE-778 A09	Plausível
T-FX1-04 F10, P1, P2	I / Confidencialidade	Um agente com acesso a um token de F10 ou D0 pode ler o campo password do perfil serializado no JWT. O token assinado contém o hash MD5 sem sal da senha, permitindo tentativa de recuperação offline e eventual acesso indevido à conta do titular.	CWE-522, CWE-916 A02	Confirmada no T1 (V2)
T-FX1-05 D2, P2, F09	D / Disponibilidade	Um cliente com credenciais válidas pode emitir sessões repetidamente em P2 e alimentar D2 explorando a falta de limite explícito de entradas e expurgo no mapa. Com volume suficiente, o processo pode degradar a autenticação e o atendimento das demais rotas.	CWE-400 A04	Plausível
T-FX1-06 P2	E / Autorização	Um agente com acesso ao código da versão pode tentar apresentar um JWT privilegiado às rotas que confiam na chave de P2. A chave privada embutida compromete a separação entre emissor e cliente e pode permitir que o agente se atribua um papel reservado.	CWE-321 A02	Plausível

Fonte: elaboração própria.

D, R, E, A e D indicam dano, reprodutibilidade, explorabilidade, usuários afetados e descoberta. Os números de controle pertencem ao ASVS 5.0.0. Os códigos de guias da OWASP remetem ao Apêndice A.

Quadro 19 - Parte B do FX1 Priorização e tratamento

ID	Controle existente	D	R	E	A	D	Média	Mitigação, camada e referências	Decisão
T-FX1-01	A mensagem de credenciais inválidas retorna HTTP 401. A amostra de V6 permaneceu sem bloqueio.	8	8	9	7	8	8,0 Alto	Aplicar atraso progressivo por conta e origem, registrar tentativas distribuídas e exigir segundo fator nas contas privilegiadas. Evitar bloqueio permanente imposto por terceiros. Preventivo e detectivo / aplicação. ASVS 6.1.1, 6.3.1. Guia AUTH. LGPD, art. 46.	Mitigar
T-FX1-02	A aplicação calcula hash da senha e filtra contas apagadas. O e-mail continua interpolado na consulta SQL.	10	10	10	10	9	9,8 Alto	Buscar a conta por e-mail com parâmetros vinculados e verificar a senha em operação separada. Aplicar a mesma regra a entradas do login e manter validação de tipo e tamanho. Preventivo / aplicação e dados. ASVS 1.2.4. Guia SQLI. LGPD, art. 46.	Mitigar
T-FX1-03	O registro HTTP documenta requisição, origem aparente, horário, status e agente de usuário.	6	7	7	6	6	6,4 Médio	Emitir evento estruturado para sucesso, falha e encerramento. Correlacionar ID interno, horário, origem validada, resultado e referência de sessão sem gravar senha ou token integral. Enviar a destino separado. Detectivo / aplicação e processo. ASVS 16.2.1, 16.3.1, 16.4.2. Guia LOG. LGPD, art. 46.	Mitigar
T-FX1-04	A assinatura RS256 protege a integridade do token. O campo password está incluído no objeto serializado.	8	10	8	8	9	8,6 Alto	Emitir JWT com um conjunto explícito de claims, sem o modelo de usuário. Migrar MD5 para Argon2id com sal único e custo calibrado, invalidar os tokens antigos e redefinir credenciais expostas quando aplicável. Preventivo e corretivo / aplicação e dados. ASVS 14.1.1, 14.2.6, 11.4.1. Guia PASS. LGPD, art. 46.	Mitigar
T-FX1-05	O analisador de corpo limita o tamanho por requisição. O código do mapa não documenta TTL nem capacidade.	7	6	7	8	6	6,8 Médio	Limitar sessões por conta, expurgar entradas expiradas, limitar taxa de login por conta e origem e medir uso do mapa e latência da rota. Preventivo e detectivo / aplicação. ASVS 2.4.1, 7.1.2. Guia SESS. LGPD, art. 46.	Mitigar

ID	Controle existente	D	R	E	A	D	Média	Mitigação, camada e referências	Decisão
T-FX1-06	O middleware verifica a assinatura em rotas protegidas. O material de assinatura está na distribuição do laboratório.	10	7	8	9	8	8,4 Alto	Provisionar chave exclusiva por implantação em gestor de segredos, rotacionar o material, revogar tokens antigos e fixar algoritmo, emissor, audiência, tipo e expiração no verificador. Preventivo e corretivo / aplicação e operação. ASVS 9.1.2, 13.3.1, 13.3.4. Guia SECRETS. LGPD, art. 46.	Mitigar

Fonte: elaboração própria.

6.1.5 Justificativas e critérios de aceite

T-FX1-01 Tentativas repetidas no login

Evidência V6. HTTP 401 nas 15 tentativas incorretas e HTTP 200 no login correto em seguida.

Dano (8) Uma senha acertada abre acesso a dados e ações da conta.

Reprodutibilidade (8) A sequência de falhas foi reproduzida no T1.

Explorabilidade (9) Uma requisição repetida ao login dispensa sessão prévia.

Usuários afetados (7) Contas com senhas previsíveis são as mais expostas.

Descoberta (8) O formulário e a rota de autenticação são públicos.

Aceite Em conta de teste, a série configurada deve acionar atraso ou contenção. Uma segunda conta legítima deve continuar acessível.

T-FX1-02 Injeção SQL na autenticação

Evidência V1. A M1 registrou bypass do login administrativo e confirmação booleana pelo sqlmap.

Dano (10) O bypass administrativo pode atingir dados de vários titulares e funções privilegiadas.

Reprodutibilidade (10) O T1 preservou requisição e resposta do bypass.

Explorabilidade (10) O caminho observado exige apenas acesso anônimo à rota e um cliente HTTP.

Usuários afetados (10) O papel obtido permite alcançar operações com alcance coletivo.

Descoberta (9) A rota é pública e a consulta vulnerável consta do código.

Aceite A entrada usada em V1 deve receber falha genérica de autenticação, sem JWT. O login com credenciais válidas deve continuar funcionando.

T-FX1-03 Atribuição incompleta de logins

Evidência server.ts, middleware Morgan. O formato HTTP combinado não carrega o identificador autenticado emitido no evento.

Dano (6) A deficiência retarda resposta e investigação de contas comprometidas.

Reprodutibilidade (7) A estrutura do log é fixa e se repete em cada chamada.

Explorabilidade (7) A disputa exige um acesso ou tentativa seguida de investigação.

Usuários afetados (6) Cada evento sem correlação pode afetar um titular.

Descoberta (6) É preciso conhecer o formato dos registros ou investigá-los.

Aceite Verificar três eventos correlacionados no destino e confirmar que o serviço de loja não pode alterar entradas já gravadas.

T-FX1-04 Hash de senha no JWT

Evidência V2. JWT de conta de teste decodificado com campo password e resumo MD5 conferido.

Dano (8) O resumo exposto permite testar senhas sem passar pelo servidor.

Reprodutibilidade (10) O T1 confirmou a presença do campo com uma conta própria.

Explorabilidade (8) Ler o payload exige o token, e a busca de senha depende da sua força.

Usuários afetados (8) A mesma estrutura do JWT é usada em diferentes contas.

Descoberta (9) Os campos do JWT são visíveis por decodificação Base64url.

Aceite Inspecionar JWT, login e whoami com fields. Nenhuma resposta deve incluir hash, segredo TOTP ou outros campos reservados.

T-FX1-05 Exaustão de sessões e autenticação

Evidência routes/login.ts e lib/insecurity.ts. O mapa em memória é preenchido em login e o caminho de emissão não define limite por conta.

Dano (7) O processo de autenticação é compartilhado com a loja.

Reprodutibilidade (6) A taxa e a duração necessárias para degradação dependem dos recursos locais.

Explorabilidade (7) Uma conta válida basta para gerar novas entradas ao longo do tempo.

Usuários afetados (8) A saturação do Node.js pode afetar todas as contas na instância.

Descoberta (6) O crescimento do mapa exige inspeção de código ou instrumentação.

Aceite Teste local com carga limitada deve demonstrar memória estabilizada, expurgo das entradas e atendimento das chamadas legítimas.

T-FX1-06 Chave de assinatura distribuída

Evidência lib/insecurity.ts contém material de assinatura fixo da demonstração. A verificação no laboratório foi documental.

Dano (10) Um JWT aceito com papel privilegiado afeta operações administrativas.

Reprodutibilidade (7) O efeito depende das verificações específicas da rota e não foi ensaiado no T1.

Explorabilidade (8) O agente precisa conhecer a estrutura do token e produzir assinatura compatível.

Usuários afetados (9) A chave é compartilhada entre contas da instância de demonstração.

Descoberta (8) O material está presente no código versionado.

Aceite Tokens com chave antiga, algoritmo inesperado ou claims inválidas devem ser recusados. O repositório e a imagem não devem conter chave privada ativa.

6.1.6 Conclusão do fluxo

A primeira correção incide na consulta de credenciais. Mesmo após parametrizá-la, as sessões ainda dependeriam de chaves e claims adequadas. A retirada de hash do token reduz exposição, enquanto a migração da senha e a revogação de tokens antigos limitam o efeito do material já emitido.

Risco residual esperado após o tratamento decorre de credenciais já comprometidas ou reutilizadas, abuso distribuído e roubo de sessão antes da expiração. A mitigação requer verificar o caminho normal de login, os casos negativos e o reaproveitamento de token após encerramento.

6.2 FX2 CADASTRO E RECUPERAÇÃO DE SENHA

O visitante cria uma conta e escolhe a pergunta de segurança da demonstração. A interface envia uma segunda requisição que associa a resposta ao ID criado. Na recuperação, o visitante consulta a pergunta vinculada ao e-mail e envia a resposta com a nova senha.

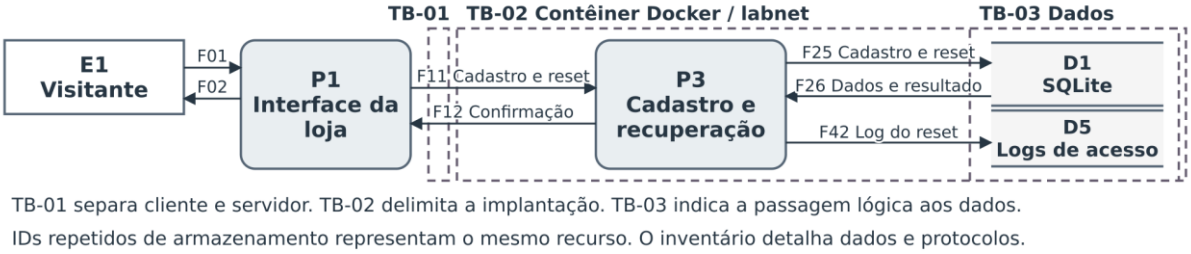
6.2.1 Ficha do fluxo

Quadro 20 - Identificação e condições do FX2

Campo	Descrição
ID e função	FX2 / Cadastro e recuperação de senha
Responsável e revisor propostos	Leonardo Pacheco B Dias / Diego Fonseca da Silva
Ator e gatilho	Visitante E1 no envio do cadastro ou na opção de senha esquecida.
Pré-condições	Cadastro com dados válidos. Na recuperação, conta com resposta de segurança associada. O roteiro da M1 usou dados sintéticos.
Resultado esperado	Conta criada com papel de cliente e recuperação que altera somente a conta correspondente à prova apresentada.

Fonte: elaboração própria.

Figura 4 - Recorte do DFD do FX2



Fonte: elaboração própria.

Quadro 21 - Requisições e evidências do FX2

Método e rota	Base	Observação
POST /api/Users e POST /api/SecurityAnswers/	M1 V7 e código	Registro de usuário e associação separada. A M1 testou chamadas sem vínculo e com ID explícito.
GET /api/SecurityQuestions	Código v20.2.0	Consulta ao catálogo de perguntas para o formulário.
GET /rest/user/security-question?email=…	M1 V7	Retorno da pergunta de conta sintética no histórico HTTP.
POST /rest/user/reset-password	M1 V7	Quatro falhas e sucesso na quinta tentativa. Extrato A2. Login posterior pertence a FX1.

Fonte: OWASP Juice Shop (2026), Silva *et al.* (2026) e elaboração própria.

Quadro 22 - Elementos percorridos no FX2

Nº	De	Para	Seta	Dados trafegados	Protocolo e formato	Fronteira
1	E1	P1	F01	Credenciais, cadastro, recuperação, navegação e arquivos públicos	Interface web / formulário	Sem travessia
2	P1	E1	F02	Formulários, identidade inicial e respostas públicas	Interface web / renderização	Sem travessia
3	P1	P3	F11	Cadastro, IDs, e-mail, resposta e nova senha	HTTP / JSON	TB-01 TB-02
4	P3	P1	F12	Confirmações de cadastro, pergunta e resultado do reset	HTTP / JSON	TB-01 TB-02
5	P3	D1	F25	Conta, pergunta, HMAC da resposta e hash de nova senha	Sequelize / SQL local	TB-03
6	D1	P3	F26	Modelos, pergunta e resultado da gravação	Sequelize / SQL local	TB-03
7	P3	D5	F42	Método, URL inclusive query string, origem, horário e status de cadastro ou reset	Escrita local / log HTTP	TB-03

Fonte: elaboração própria.

Quadro 23 - Classificação dos dados no FX2

Dado	Classificação	Localização	CID crítica
E-mail e ID de usuário	Dado pessoal quando identificável	F11, F12, D1 e possivelmente F42	Confidencialidade
Pergunta e vínculo com conta	Dado pessoal quando associado	F11, F12, F25, F26 e D1	Confidencialidade
Resposta e senha nova	Credenciais ou segredos	F11, HMAC e hash em D1	Confidencialidade
Papel e estado de cadastro	Interno e dado pessoal vinculado	F12, F25 e D1	Integridade

Fonte: Brasil (2018), OWASP Juice Shop (2026) e elaboração própria.

Quadro 24 - Controles identificados no FX2

Controle	Elemento	Base de constatação
Unicidade de e-mail e de UserId na resposta	P3 e D1	models/user.ts e models/securityAnswer.ts. A M1 registrou HTTP 400 em tentativa de segunda resposta.
HMAC da resposta e hash da senha	P3, F25 e D1	routes/resetPassword.ts e modelos. A chave HMAC da demonstração está no código.
Limite de 100 solicitações em cinco minutos no reset	P3 e F11	Cabeçalhos de V7 e server.ts. A cota não foi esgotada na evidência.

Controle	Elemento	Base de constatação
Verificação de senha nova e repetição	P3	routes/resetPassword.ts. O código rejeita vazio ou divergência.

Fonte: OWASP Juice Shop (2026) e Silva *et al.* (2026).

6.2.2 Matriz STRIDE por elemento

Os códigos NA1 a NA13 remetem às justificativas do Apêndice A. Cada célula preenchida vincula uma ameaça do FX2 ou registra N/A para a categoria aplicável ao tipo. O detalhamento das setas consta do quadro de percurso.

Quadro 25 - Matriz STRIDE do FX2

Elemento	S	T	R	I	D	E
D1 SQLite		T-FX2-02		N/A 7	T-FX2-05	
D5 Logs de acesso		N/A 9	T-FX2-03	N/A 9	N/A 9	
E1 Visitante	T-FX2-01		T-FX2-03			
P1 Interface da loja	N/A 8	N/A 13	N/A 8	T-FX2-04	N/A 10	N/A 8
P3 Cadastro e recuperação	T-FX2-01	T-FX2-02	T-FX2-03	T-FX2-04	T-FX2-05	T-FX2-06
F01		N/A 13		N/A 13	N/A 6	
F02		N/A 13		N/A 13	N/A 6	
F11		T-FX2-02		N/A 4	T-FX2-05	
F12		N/A 3		T-FX2-04	N/A 6	
F25		T-FX2-02		N/A 4	T-FX2-05	
F26		N/A 3		N/A 4	N/A 6	
F42		N/A 9		T-FX2-04	N/A 6	

Fonte: elaboração própria.

6.2.3 Questionário do fluxo

Compreensão do fluxo

Q1 FX2 cria a identidade inicial e permite recuperar uma conta. Uma resposta previsível em P3 pode substituir a senha de um titular, como em T-FX2-01.

Q2 E1 pode iniciar cadastro ou reset sem sessão. A associação na SPA ocorre após o retorno do cadastro. Na M1 o script também usou um JWT no ensaio de associação com ID explícito, o que não prova exigência universal de autenticação nessa rota.

Q3 E1 envia dados por F01. P1 chama P3 por F11 em HTTP, com corpo JSON ou query string na consulta. P3 lê e grava D1 por F25 e F26, responde por F12 e registra metadados por F42 em D5.

Q4 F11 e F12 atravessam TB-01 e TB-02. F25, F26 e F42 atravessam TB-03, onde registros da conta, recuperação e logs passam a integrar o estado do servidor.

Q5 E-mail e ID são dados pessoais quando vinculáveis. Senha e resposta são segredos. A pergunta associada também diz respeito à conta. Um valor de campo livre pode exigir nova classificação conforme seu conteúdo efetivo.

Q6 JSON expõe role, UserId e SecurityQuestionId como campos de interesse e answer, new e repeat no reset. O e-mail em query string constitui entrada da API e risco de registro de dado pessoal.

Q7 O código aplica unicidade, HMAC, hash e verificação básica da nova senha. V7 observou quatro recusas, um sucesso e cabeçalhos que informam a cota. A unicidade impediu a segunda associação em conta já configurada.

Spoofing

S1 A recuperação de P3 compara a resposta com HMAC armazenado em D1 para o e-mail. O cadastro não prova posse do endereço apenas por recebê-lo. P3 acessa SQLite por biblioteca local.

S2 A recuperação atual usa conhecimento persistente, sem credencial de uso único no percurso. O token recebido depois do novo login pertence ao FX1, que também documenta a expiração ausente nas amostras.

S3 T-FX2-01 mostra que conhecer ou adivinhar a resposta de outro titular é suficiente no cenário de teste. T-FX2-02 considera conta incompleta, cuja associação pode depender de dado controlado pelo solicitante.

Tampering

T1 Campos de cadastro e IDs podem ser alterados antes de F11. P3 grava estado durável da conta em D1. A atribuição de role e o vínculo da resposta exigem origem confiável no servidor.

T2 A rota valida parte dos campos e D1 impõe restrições de unicidade. O recurso de cadastro recebe campos do corpo, e a resposta de segurança é gravada separadamente com UserId explícito.

T3 HMAC autentica o valor de comparação em D1, mas não aumenta a entropia da resposta e a chave da demonstração está distribuída. O tráfego observado é HTTP e o esquema da API aceita papéis definidos no modelo.

Repudiation

R1 F42 registra acesso HTTP ao cadastro e reset, com horário, método, URL, origem e status. Não há evidência de vínculo entre solicitação e prova de posse de canal do titular.

R2 A rotação de D5 limita retenção. A fonte não demonstrou proteção contra edição por processo privilegiado. Um nome de arquivo audit.json do rotator não equivale a trilha de auditoria da aplicação.

R3 Um visitante pode negar a troca da senha. O e-mail alvo é informação do pedido e não identifica o autor. T-FX2-03 trata essa diferença.

Information Disclosure

I1 F12 revela pergunta vinculada em V7. A resposta HTTP 200 de reset preservada em V7 inclui um campo password com hash. A query string pode deixar e-mail em logs ou histórico.

I2 A consulta pública devolve associação desnecessária para um reset por canal verificado. A confirmação da troca precisa informar o resultado, sem devolver o modelo completo do usuário.

I3 F11 e F12 usam HTTP local. D1 guarda hash de senha e HMAC da resposta, com limitações documentadas. Não se comprovou cifragem em repouso dos dados do arquivo SQLite.

Denial of Service

D1 Criação de conta, carteira e resposta gera escritas no SQLite. Uma sequência automatizada pode pressionar o mesmo processo usado por outras rotas, hipótese T-FX2-05.

D2 A cota de reset é 100 em cinco minutos por chave derivada de IP no código. O tratamento de proxy merece validação. A M1 não mediu o centésimo primeiro pedido. O cadastro não passa por esse middleware de reset.

D3 O mecanismo atual depende de Express e SQLite. Um canal externo verificado de recuperação integra a solução proposta e exige política de disponibilidade e de reenvio.

Elevation of Privilege

E1 O servidor consulta conta e resposta ao redefinir. O fluxo de cadastro deve forçar papel mínimo, e a associação deve usar identidade gerada e vinculada à transação.

E2 A tomada de conta foi confirmada por V7. A atribuição de role privilegiado em T-FX2-06 tem evidência de código e teste upstream, sem reprodução pela equipe no laboratório documentado.

E3 P3 executa no mesmo processo e identidade de sistema que os demais módulos. O acesso de escrita ao SQLite abrange conta e resposta. Uma aplicação real deve limitar operação e campo por serviço, mesmo em processo compartilhado.

Fechamento do fluxo

V1 T-FX2-06 tem média 9,0 pelo alcance dos papéis privilegiados. T-FX2-01, com média 8,8, é a ameaça de maior prioridade já demonstrada no fluxo.

V2 V7 confirma o reset com palpite e a obtenção da pergunta, vinculados a T-FX2-01 e T-FX2-04. O caso negativo de associação duplicada delimita T-FX2-02. As demais ameaças ficam plausíveis.

V3 Seria necessário validar criação com role alterado, associação para conta ainda sem resposta, alcance do limitador e invalidação de sessões após reset no ambiente da equipe.

6.2.4 Registro de ameaças

Quadro 26 - Parte A do FX2 Identificação das ameaças

ID e elementos principais	STRIDE e propriedade	Cenário	CWE e OWASP 2021	Status
T-FX2-01 P3, E1	S / Autenticidade	Um visitante E1 pode redefinir a senha de uma conta em P3 por F11 se adivinhar sua resposta de segurança. A recuperação baseada em conhecimento previsível aceita o palpite correto dentro da janela observada, permitindo assumir a conta sem a senha anterior.	CWE-640 A04	Confirmada no T1 (V7)
T-FX2-02 P3, F11, F25	T / Integridade	Um visitante E1 pode tentar vincular uma resposta própria a uma conta ainda sem associação em P3 e D1. O POST separado carrega o UserId fornecido pelo cliente. Se o servidor aceitar um ID alheio elegível, o agente passa a controlar o dado usado na recuperação dessa conta.	CWE-639, CWE-862 A01	Plausível
T-FX2-03 D5, P3, E1	R / Não repúdio	Um agente que solicite reset em P3 pode negar sua participação após trocar a senha de outra pessoa. Em F42 e D5, método, status e endereço de origem não estabelecem o vínculo entre a operação, o titular, a prova de recuperação e a alteração de estado.	CWE-778 A09	Plausível

ID e elementos principais	STRIDE e propriedade	Cenário	CWE e OWASP 2021	Status
T-FX2-04 F12, P3, P1	I / Confidencialidade	Um visitante E1 pode consultar P3 com um e-mail e obter em F12 a pergunta vinculada, explorando a diferença de resposta do endpoint. Isso revela uma associação de recuperação e fornece contexto para atacar a conta. O e-mail em query string também pode aparecer em F42.	CWE-203, CWE-598 A07	Confirmada no T1 (V7)
T-FX2-05 P3, D1, F11	D / Disponibilidade	Um visitante E1 pode submeter cadastros em sequência para P3 e acumular registros em D1. A criação pública de conta e carteira sem orçamento específico identificado pode ocupar escrita no SQLite, CPU e disco, degradando cadastro e recuperação.	CWE-400 A04	Plausível
T-FX2-06 P3	E / Autorização	Um visitante E1 pode tentar enviar role privilegiado no cadastro em F11. P3 entrega o corpo à criação genérica e D1 aceita papéis previstos no esquema. Sem lista explícita de campos ou regra de atribuição do papel inicial, a conta criada pode ganhar autorização de administrador ou contabilidade.	CWE-915, CWE-269 A01	Plausível

Fonte: elaboração própria.

D, R, E, A e D indicam dano, reprodutibilidade, explorabilidade, usuários afetados e descoberta. Os números de controle pertencem ao ASVS 5.0.0. Os códigos de guias da OWASP remetem ao Apêndice A.

Quadro 27 - Parte B do FX2 Priorização e tratamento

ID	Controle existente	D	R	E	A	D	Média	Mitigação, camada e referências	Decisão
T-FX2-01	Há comparação HMAC e limitador de 100 requisições em cinco minutos. Cinco solicitações chegaram ao mecanismo de reset.	9	9	9	8	9	8,8 Alto	Substituir a pergunta por recuperação com token aleatório de uso único, vida curta e vínculo ao titular por canal verificado, preservando MFA quando ativo. Notificar a troca e encerrar sessões antigas segundo política. Preventivo e corretivo / aplicação. ASVS 6.4.2, 6.4.3, 7.4.3. Guia RESET. LGPD, art. 46.	Mitigar

ID	Controle existente	D	R	E	A	D	Média	Mitigação, camada e referências	Decisão
T-FX2-02	UserId é único em D1. A M1 obteve HTTP 400 ao tentar registrar segunda resposta para a mesma conta.	8	6	7	5	7	6,6 Médio	Durante a migração, acoplar criação da conta e associação em transação única com o ID gerado no servidor. Remover a gravação pública isolada quando o novo reset entrar em serviço. Preventivo / aplicação e dados. ASVS 2.3.1, 2.3.3, 8.2.2. Guia AUTHZ. LGPD, art. 46.	Mitigar
T-FX2-03	Há log HTTP diário. A prova da recuperação depende do conhecimento da resposta.	7	7	7	6	6	6,6 Médio	Correlacionar abertura, consumo e falhas de recuperação a ID opaco, horário, origem e resultado. Proteger a trilha contra alteração e notificar o canal já cadastrado. Detectivo e corretivo / aplicação e processo. ASVS 16.2.1, 16.2.5, 16.4.2. Guia LOG. LGPD, art. 46.	Mitigar
T-FX2-04	A rota não devolve a resposta de segurança. A pergunta associada é visível sem autenticação.	5	9	9	7	8	7,6 Alto	Retirar a consulta pública da pergunta. Receber solicitação de recuperação no corpo, responder com status, conteúdo e tempo comparáveis. Omitir hashes da resposta do reset e excluir e-mails desnecessários dos logs de acesso. Preventivo / aplicação e processo. ASVS 6.3.8, 14.2.1, 16.2.5. Guia RESET. LGPD, art. 46.	Mitigar
T-FX2-05	A unicidade do e-mail impede duplicata da mesma conta. O limitador de reset não cobre o cadastro.	6	7	8	7	7	7,0 Alto	Limitar cadastros por origem e período com controle contra abuso distribuído, verificar endereço de cadastro e remover contas incompletas conforme regra de retenção. Preventivo e detectivo / aplicação e dados. ASVS 2.4.1. Guia AUTH. LGPD, art. 46.	Mitigar
T-FX2-06	O modelo aplica customer como padrão e valida o conjunto de papéis aceitos. Esses controles não restringem o papel recebido a customer.	10	8	9	9	9	9,0 Alto	Usar um DTO de cadastro com campos permitidos e gravar customer a partir de regra interna. Alterar papel somente em operação administrativa distinta, autorizada e auditada. Preventivo / aplicação. ASVS 8.2.1, 8.2.3, 8.3.1. Guia MASS. LGPD, art. 46.	Mitigar

Fonte: elaboração própria.

6.2.5 Justificativas e critérios de aceite

T-FX2-01 Tomada de conta por resposta previsível

Evidência V7. Resposta previsível aceita na quinta tentativa e login posterior com a nova senha.

Dano (9) A senha alterada concede acesso aos dados do titular e pode impedir seu login.

Reprodutibilidade (9) O T1 repetiu a tentativa até o quinto palpite e confirmou o acesso.

Explorabilidade (9) A rota pública exige e-mail e resposta adivinhável, sem sessão inicial.

Usuários afetados (8) O efeito direto é por conta, mas o mecanismo é comum a todas.

Descoberta (9) O formulário revela a pergunta associada e facilita a seleção dos palpites.

Aceite Token expirado, já usado ou de outra conta deve falhar. A resposta de recuperação não deve identificar se o e-mail está cadastrado.

T-FX2-02 Associação indevida de resposta de segurança

Evidência server.ts, models/securityAnswer.ts e register.component.ts. V7 registrou UserId nulo sem associação e HTTP 400 para sobrescrita já existente.

Dano (8) A associação indevida pode preparar a tomada da conta ainda sem resposta.

Reprodutibilidade (6) É necessária uma conta alvo sem registro e o caso não foi reproduzido.

Explorabilidade (7) A chamada é simples, mas exige conhecer um ID elegível.

Usuários afetados (5) A janela restringe o ataque a contas com configuração incompleta.

Descoberta (7) O campo UserId é exposto pelo contrato e pela implementação da interface.

Aceite Um cliente não deve conseguir associar resposta a ID indicado por ele. A criação incompleta deve ser revertida sem deixar conta apta a recuperação indevida.

T-FX2-03 Contestação de redefinição de senha

Evidência routes/resetPassword.ts e server.ts. A resposta do reset e o log HTTP não identificam quem apresentou o conhecimento secreto.

Dano (7) Uma disputa de conta pode exigir investigação e reversão sem trilha suficiente.

Reprodutibilidade (7) O registro genérico é o mesmo mecanismo para todos os resets.

Explorabilidade (7) Uma redefinição anônima fornece pouco material para atribuição individual.

Usuários afetados (6) Os atingidos são principalmente titulares que sofreram reset indevido.

Descoberta (6) A lacuna aparece ao comparar a rota com o conteúdo do log.

Aceite Uma operação de teste deve gerar eventos correlacionáveis e uma notificação, sem persistir resposta, nova senha ou token recuperável no log.

T-FX2-04 Divulgação da pergunta vinculada ao e-mail

Evidência V7. Consulta anônima retornou a pergunta associada. routes/securityQuestion.ts distingue resposta com pergunta e objeto vazio.

Dano (5) O retorno revela associação e tema da pergunta, sem entregar a resposta secreta.

Reprodutibilidade (9) O retorno da pergunta foi capturado na M1.

Explorabilidade (9) A consulta é anônima e requer apenas um e-mail candidato.

Usuários afetados (7) A operação se repete para contas com pergunta associada.

Descoberta (8) O formulário usa o endpoint e o contraste de saída consta do código.

Aceite Em amostra local, e-mails cadastrados e não cadastrados devem receber resposta equivalente, com variação temporal compatível. A resposta do reset deve omitir o hash e o log deve omitir o identificador bruto.

T-FX2-05 Consumo de recursos por cadastros automatizados

Evidência server.ts e fluxo do cadastro. Criação de usuário e carteira, com resposta de segurança em operação separada.

Dano (6) Acúmulo de registros e competição por escrita degradam a mesma base usada pelas contas.

Reprodutibilidade (7) Cadastros com identificadores distintos são possíveis, mas a saturação não foi medida.

Explorabilidade (8) A rota pública aceita requisições com dados de cadastro.

Usuários afetados (7) A degradação do SQLite pode afetar operações de outros usuários.

Descoberta (7) O custo das operações é identificável no código e no formulário.

Aceite Uma sequência de cadastros sintéticos acima da política deve ser contida, com criação e reset legítimos preservados.

T-FX2-06 Atribuição de papel privilegiado no cadastro

Evidência server.ts e models/user.ts. O middleware do desafio registra role admin e prossegue. O teste upstream user.test.ts documenta o comportamento esperado.

Dano (10) O papel privilegiado pode alcançar dados e operações coletivas.

Reprodutibilidade (8) Há caminho e teste upstream, sem reprodução no laboratório da equipe.

Explorabilidade (9) A operação de registro é pública e o vetor é um campo do corpo.

Usuários afetados (9) O papel pode afetar contas e compras de diversos titulares.

Descoberta (9) O campo role é reconhecível pelo esquema e pelo código do desafio.

Aceite Pedidos de cadastro com role admin, accounting ou deluxe devem ser rejeitados ou gravados exclusivamente como customer. O perfil emitido deve refletir o papel persistido.

6.2.6 Conclusão do fluxo

O papel inicial precisa ser atribuído no servidor. A recuperação deve abandonar perguntas previsíveis e adotar prova de posse de canal com uso único e prazo curto. Essas correções tratam causas diferentes e precisam de verificação independente.

Após a substituição, o risco residual concentra-se no comprometimento do canal de recuperação e na automação de solicitações. Respostas uniformes, cotas por conta e origem, trilha protegida e alerta ao titular reduzem exposição e tempo de reação.

6.3 FX3 CESTA, CHECKOUT E REGISTRO DO PEDIDO

O comprador consulta a cesta, inclui ou ajusta itens, escolhe endereço e meio de pagamento e confirma a compra. O servidor calcula o valor, registra o pedido na coleção em memória e grava um PDF. O histórico e o download permitem consultar o resultado.

6.3.1 Ficha do fluxo

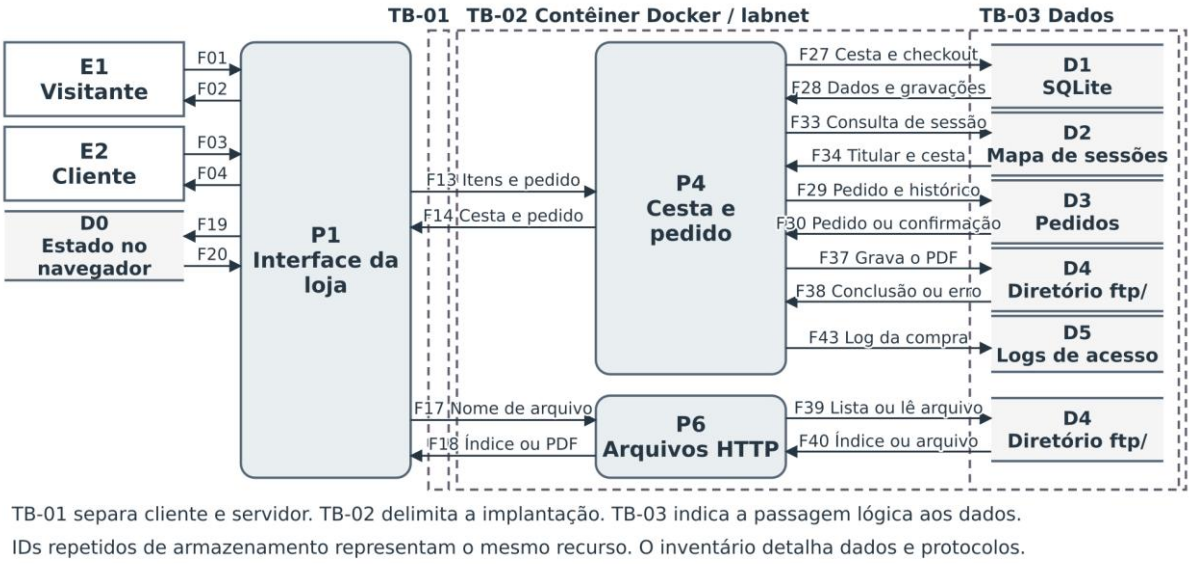
Quadro 28 - Identificação e condições do FX3

Campo	Descrição
ID e função	FX3 / Cesta, checkout e registro do pedido

Campo	Descrição
Responsável e revisor propostos	Gustavo Gonçalves Trindade / João Victor Rodrigues Santos
Ator e gatilho	Comprador E2 com sessão ao abrir a cesta ou confirmar o pedido. A leitura pública de arquivos em P6 inclui E1 como agente no recorte.
Pré-condições	Token da conta, cesta e itens, endereço e opção de entrega quando aplicáveis, cartão sintético ou carteira de demonstração.
Resultado esperado	Pedido associado ao comprador e a referências válidas, cesta finalizada e comprovante acessível apenas ao titular na solução pretendida.

Fonte: elaboração própria.

Figura 5 - Recorte do DFD do FX3



Fonte: elaboração própria.

Quadro 29 - Requisições e evidências do FX3

Método e rota	Base	Observação
GET /rest/basket/:id	M1 V3 e V4	HTTP 200 com token de outra conta no ensaio de leitura e erro verboso com header malformado. Figuras 9 e 10 e extrato A3.
POST /api/BasketItems e PUT /api/BasketItems/:id	Código v20.2.0	server.ts e routes/basketItems.ts. Adição, ajuste e consulta de estoque.
GET e POST /api/Addresss, GET e POST /api/Cards	Código v20.2.0	Rotas de endereço e cartão. A grafia Addresss segue a API.
GET /api/Deliverys e POST /rest/basket/:id/checkout	Código e teste upstream	server.ts e routes/order.ts. Há teste upstream de retorno de orderId em basket.test.ts.
GET /rest/order-history	Código e teste upstream	Consulta vinculada ao e-mail transformado na coleção de pedidos. Teste em order-history.test.ts.

Método e rota	Base	Observação
GET /ftp/ e GET /ftp/order_{id}.pdf	M1 V5 para listagem e documento de exemplo. Código para PDF de pedido	order-completion.component.ts, routes/order.ts e fileServer.ts. Figura 11.

Fonte: OWASP Juice Shop (2026), Silva *et al.* (2026) e elaboração própria.

Quadro 30 - Elementos percorridos no FX3

Nº	De	Para	Seta	Dados trafegados	Protocolo e formato	Fronteira
1	E1	P1	F01	Credenciais, cadastro, recuperação, navegação e arquivos públicos	Interface web / formulário	Sem travessia
2	P1	E1	F02	Formulários, identidade inicial e respostas públicas	Interface web / renderização	Sem travessia
3	E2	P1	F03	Ações autenticadas de sessão, cesta e compra	Interface web / formulário	Sem travessia
4	P1	E2	F04	Perfil, itens, estado de compra e comprovante	Interface web / renderização	Sem travessia
5	P1	P4	F13	JWT, itens, endereço, cartão de teste e IDs do checkout	HTTP / JSON	TB-01 TB-02
6	P4	P1	F14	Cesta, meios de pagamento, resultado e confirmação de pedido	HTTP / JSON	TB-01 TB-02
7	P1	P6	F17	Caminho de listagem ou nome do arquivo	HTTP / caminho	TB-01 TB-02
8	P6	P1	F18	HTML de listagem ou bytes do documento	HTTP / HTML, PDF ou Markdown	TB-01 TB-02
9	P1	D0	F19	JWT, cookie e ID da cesta	Web Storage / cookie	Sem travessia
10	D0	P1	F20	JWT e ID da cesta para requisições	Web Storage / cookie	Sem travessia
11	P4	D1	F27	Cesta, estoque, endereços, cartões, carteira e entrega	Sequelize / SQL local	TB-03
12	D1	P4	F28	Linhas consultadas e confirmação de gravações	Sequelize / SQL local	TB-03
13	P4	D3	F29	Registro do pedido ou consulta do histórico	MarsDB / documento em memória	TB-03
14	D3	P4	F30	Documento de pedido ou resultado da gravação	MarsDB / documento em memória	TB-03

Nº	De	Para	Seta	Dados trafegados	Protocolo e formato	Fronteira
15	P4	D2	F33	Consulta do JWT para obter titular e cesta	Acesso em memória	TB-03
16	D2	P4	F34	Perfil associado e ID de cesta	Acesso em memória	TB-03
17	P4	D4	F37	Gravação do comprovante e identificação do pedido	Sistema de arquivos / PDF	TB-03
18	D4	P4	F38	Fim da escrita ou erro do arquivo	Sistema de arquivos / PDF	TB-03
19	P6	D4	F39	Leitura de diretório ou arquivo por nome	Sistema de arquivos / leitura	TB-03
20	D4	P6	F40	Metadados de arquivos ou documento	Sistema de arquivos / leitura	TB-03
21	P4	D5	F43	Método, URL, horário, origem e status de cesta e checkout	Escrita local / log HTTP	TB-03

Fonte: elaboração própria.

Quadro 31 - Classificação dos dados no FX3

Dado	Classificação	Localização	CID crítica
Itens, quantidade e preço	Público no catálogo e dado pessoal quando vinculado ao pedido	F13, F14, D1, D3 e PDF em D4	Integridade
Endereço, nome e telefone	Dado pessoal quando identificável	F13, F14 e D1. Referência de endereço em D3	Confidencialidade
Cartão sintético, validade e titular	Dado de pagamento quando real e identificável	F13, D1 e campos mascarados em F14 nas consultas específicas	Confidencialidade
JWT, IDs de cesta, entrega, cartão e pedido	Credencial e identificadores vinculáveis	D0, D2, F13, D1, D3 e D4	Integridade
E-mail associado ao pedido	Dado pessoal quando identificável	PDF em D4 e forma parcialmente mascarada em D3	Confidencialidade

Fonte: Brasil (2018), OWASP Juice Shop (2026) e elaboração própria.

Quadro 32 - Controles identificados no FX3

Controle	Elemento	Base de constatação
Autenticação na cesta e atribuição de UserId	P4, F13 e D2	server.ts e lib/insecurity.ts. A M1 registrou recusa sem token em V3.
Filtro de titularidade em consultas específicas de endereço e cartão	P4 e D1	routes/address.ts e routes/payment.ts. A listagem de cartão mascara o número.
Cálculo de preço e verificação de estoque	P4 e D1	routes/order.ts e routes/basketItems.ts. A checagem de estoque foi localizada nas rotas de itens.

Controle	Elemento	Base de constatação
Restrição de formato no download	P6 e D4	routes/fileServer.ts. A regra de formato não valida a titularidade do documento.

Fonte: OWASP Juice Shop (2026) e Silva *et al.* (2026).

6.3.2 Matriz STRIDE por elemento

Os códigos NA1 a NA13 remetem às justificativas do Apêndice A. Cada célula preenchida vincula uma ameaça do FX3 ou registra N/A para a categoria aplicável ao tipo. O detalhamento das setas consta do quadro de percurso.

Quadro 33 - Matriz STRIDE do FX3

Elemento	S	T	R	I	D	E
D0 Estado no navegador		N/A 11		N/A 11	N/A 10	
D1 SQLite		T-FX3-02		N/A 7	N/A 6	
D2 Mapa de sessões		N/A 7		N/A 7	N/A 6	
D3 Pedidos		T-FX3-02		N/A 7	N/A 6	
D4 Diretório ftp/		N/A 7		T-FX3-07	T-FX3-05	
D5 Logs de acesso		N/A 9	T-FX3-03	N/A 9	N/A 9	
E1 Visitante	N/A 1		N/A 1			
E2 Cliente	T-FX3-01		T-FX3-03			
P1 Interface da loja	T-FX3-01	N/A 13	N/A 8	T-FX3-04 T-FX3-07	N/A 10	N/A 8
P4 Cesta e pedido	T-FX3-01	T-FX3-02	T-FX3-03	T-FX3-04 T-FX3-07	T-FX3-05	T-FX3-06
P6 Arquivos HTTP	N/A 8	N/A 7	N/A 8	T-FX3-07	N/A 10	N/A 8
F01		N/A 13		N/A 13	N/A 6	
F02		N/A 13		N/A 13	N/A 6	
F03		N/A 13		N/A 13	N/A 6	
F04		N/A 13		N/A 13	N/A 6	
F13		T-FX3-02		N/A 4	T-FX3-05	
F14		N/A 3		T-FX3-04	N/A 6	
F17		N/A 2		N/A 4	N/A 12	
F18		N/A 3		T-FX3-07	N/A 6	
F19		N/A 11		N/A 11	N/A 6	
F20		N/A 11		N/A 11	N/A 6	
F27		T-FX3-02		N/A 4	N/A 6	
F28		N/A 3		N/A 4	N/A 6	
F29		T-FX3-02		N/A 4	N/A 6	

Elemento	S	T	R	I	D	E
F30		N/A 3		N/A 4	N/A 6	
F33		N/A 3		N/A 4	N/A 6	
F34		N/A 3		N/A 4	N/A 6	
F37		N/A 3		T-FX3-07	T-FX3-05	
F38		N/A 3		N/A 4	N/A 6	
F39		N/A 3		T-FX3-07	N/A 6	
F40		N/A 3		T-FX3-07	N/A 6	
F43		N/A 9		N/A 9	N/A 6	

Fonte: elaboração própria.

6.3.3 Questionário do fluxo

Compreensão do fluxo

Q1 FX3 transforma a intenção do comprador em pedido e registro de entrega. A consistência entre cesta, titular, forma de pagamento e comprovante determina a integridade da compra.

Q2 E2 inicia o fluxo de compra após FX1. E1 não deve operar cestas, mas consegue solicitar o diretório público de P6 e pode induzir erro com header malformado, como em V4.

Q3 F03 aciona P1. F13 e F14 usam HTTP e JSON com P4. F27 e F28 acessam SQLite, F29 e F30 a coleção de pedidos, F33 e F34 o mapa de sessão, e F37 e F38 o arquivo de comprovante. P6 lê D4 por F39 e F40 e serve o resultado por F18. F43 produz log de acesso.

Q4 As requisições de compra e arquivo passam por TB-01 e TB-02. TB-03 separa a lógica de compra dos armazenamentos. Cruzar D1, D3 e D4 exige consistência entre gravações com mecanismos diferentes.

Q5 P4 recebe token, IDs e dados de entrega e cartão de teste. D1 armazena dados cadastrais e cesta, D3 o pedido com e-mail mascarado e referências, D4 o PDF. Dados financeiros não se tornam sensíveis no sentido jurídico do art. 5º, II apenas pela natureza do campo.

Q6 Há identificadores em rota, campos ProductId, BasketId, quantity e orderDetails, header Authorization e nome do PDF em URL. São entradas da interface, API e superfície de arquivos.

Q7 V3 mostra recusa sem token. No código, consultas específicas de endereço e cartão usam UserId, e o cartão lido é mascarado. O preço parte dos produtos armazenados. V3 evidencia a falha de titularidade na cesta.

Spoofing

S1 E2 demonstra posse do token em F13. P4 usa o middleware de autenticação e o mapa de sessões para vincular a chamada ao usuário. P6 entrega arquivos elegíveis sem exigir essa prova.

S2 O bearer é emitido no FX1, fica em D0 e é lido em F20. A SPA limpa o token ao sair, e os JWTs históricos não contêm exp. A validade efetiva varia conforme o verificador da rota.

S3 Em T-FX3-01, quem possuir a credencial de outro comprador pode apresentá-la em F13. A M1 V3, por sua vez, observou acesso com a credencial da própria conta e ID de terceiro, sem falsificar identidade.

Tampering

T1 IDs e quantidades podem ser alterados na entrada F13. P4 atualiza D1 e D3 e grava D4. Um erro de consistência entre esses destinos pode deixar pedido e cesta em estados diferentes.

T2 Estoque e preço têm controles no servidor, com alcance diferente por rota. O checkout procura a cesta pelo ID recebido e lê referências do corpo. Essa diferença sustenta T-FX3-02.

T3 HTTP local não fornece integridade criptográfica de transporte. A assinatura do JWT não cobre os campos do checkout. Transações e validações de titularidade precisam abranger os objetos usados.

Repudiation

R1 F43 registra rota, horário, origem, método e status. D3 guarda orderId e estado de pedido. O trecho examinado não apresenta trilha única que correlacione esses registros ao ator validado.

R2 D5 fica no mesmo ambiente e usa rotação. D3 não é uma trilha imutável, pois seus registros de pedido mudam durante a operação de entrega.

R3 Um titular pode negar um checkout quando os registros não demonstram identidade, ID do pedido e resultado na mesma cadeia de eventos, como em T-FX3-03.

Information Disclosure

I1 V3 observou itens e UserId de outra cesta. V4 registrou erro com versão declarada do framework. F18 pode expor PDFs de pedidos, hipótese fundamentada no diretório público e no código.

I2 Mascarar número nas respostas de cartão reduz a exposição, mas D1 ainda contém o valor completo no modelo. D3 mascara o e-mail de forma parcial e o PDF contém o e-mail. Minimizar os dados exige revisar cada representação.

I3 HTTP de loopback não fornece TLS. A análise documental não demonstrou criptografia de SQLite ou PDFs. Restringir o formato do arquivo não garante confidencialidade.

Denial of Service

D1 O fluxo usa SQLite, mapa de sessão, memória para pedidos, CPU e descritores para PDF e espaço em disco. O acúmulo em D4 pode prejudicar novas compras.

D2 O código verifica estoque em rotas de itens e o parser limita o corpo. Não se identificou quota específica de checkout e de geração de PDF nos trechos examinados.

D3 A compra de demonstração usa componentes locais e simula pagamento. Não se comprovou adquirente externo nas rotas estudadas. Falhas do arquivo e da coleção local são dependências do fluxo.

Elevation of Privilege

E1 P4 exige autenticação para cesta e aplica filtros de titularidade em algumas consultas de cartão e endereço. A cesta de V3 e a busca inicial do checkout usam ID sem predicado equivalente.

E2 Sim. V3 confirma leitura horizontal em T-FX3-06. T-FX3-02 considera alteração do estado do pedido e da cesta e depende de teste próprio.

E3 O processo Node.js executa com a conta prevista na imagem e alcança D1 a D4 conforme a operação. A separação lógica no DFD não demonstra menor privilégio por módulo.

Fechamento do fluxo

V1 T-FX3-06 tem média 8,4 e evidencia quebra de titularidade em um recurso ligado a conta. T-FX3-02 tem dano potencial maior por envolver escrita e ficou em 7,8 devido à menor base empírica.

V2 V3 e V4 sustentam T-FX3-06 e T-FX3-04. V5 demonstra listagem e download de documento de exemplo, dando base a T-FX3-07 sem confirmar exposição de um PDF de cliente.

V3 A M1 não registrou o ciclo de checkout completo, nem falhas concorrentes, nem leitura cruzada de comprovante. Revalidar titularidade nas leituras e escritas e observar criação do PDF em instância de teste.

6.3.4 Registro de ameaças

Quadro 34 - Parte A do FX3 Identificação das ameaças

ID e elementos principais	STRIDE e propriedade	Cenário	CWE e OWASP 2021	Status
T-FX3-01 P4, P1, E2	S / Autenticidade	Um agente que obtenha o token de um comprador pode se apresentar como E2 em P4 por F13. O token portador armazenado em D0 é reutilizável e a limpeza local no logout não demonstra revogação no servidor. O agente pode consultar dados ou operar como o comprador.	CWE-294, CWE-613 A07	Plausível
T-FX3-02 P4, F13, F27	T / Integridade	Um comprador E2 pode alterar o identificador da cesta em F13 ou informar referências de endereço e pagamento fora da sua conta. P4 busca a cesta pelo ID recebido e grava referências no pedido. Se o checkout prosseguir, pode registrar compra inconsistente e remover itens da cesta de terceiro.	CWE-639, CWE-862 A01	Plausível
T-FX3-03 D5, P4, E2	R / Não repúdio	Um comprador E2 pode contestar a autoria de um checkout em P4 quando o registro de D5 não vincula a chamada em F43 ao identificador do pedido, à identidade validada e ao resultado do pagamento simulado. Isso dificulta reconstruir a transação e responder à disputa.	CWE-778 A09	Plausível
T-FX3-04 F14, P4, P1	I / Confidencialidade	Um visitante E1 com acesso local pode induzir erro ao enviar Authorization malformado para F13. O tratamento devolve em F14 detalhes do framework em HTML, que o agente pode usar para reconhecimento do ambiente.	CWE-209 A05	Confirmada no T1 (V4)
T-FX3-05 P4, D4, F13	D / Disponibilidade	Um comprador E2 pode disparar checkouts concorrentes em P4 e criar PDFs em D4. Sem orçamento de geração por conta e política de descarte identificados, o volume pode consumir CPU, descritores e espaço, degradando compras ou outras funções da instância.	CWE-400 A04	Plausível

ID e elementos principais	STRIDE e propriedade	Cenário	CWE e OWASP 2021	Status
T-FX3-06 P4	E / Autorização	Um comprador E2 pode solicitar em F13 o ID da cesta de outro titular. P4 valida a sessão, mas consulta D1 pelo identificador sem filtrar o dono. O agente ultrapassa a autorização da própria conta e recebe itens e vínculo com outro usuário em F14.	CWE-639 A01	Confirmada no T1 (V3)
T-FX3-07 P6, P1, P4	I / Confidencialidade	Um visitante com acesso local pode tentar localizar um comprovante em D4 e solicitá-lo a P6. O checkout grava o PDF no diretório servido via HTTP, e a entrega de arquivos não verifica titularidade. Se o arquivo estiver presente, a exposição pode incluir e-mail e detalhes do pedido.	CWE-548, CWE-862 A05	Plausível

Fonte: elaboração própria.

D, R, E, A e D indicam dano, reprodutibilidade, explorabilidade, usuários afetados e descoberta. Os números de controle pertencem ao ASVS 5.0.0. Os códigos de guias da OWASP remetem ao Apêndice A.

Quadro 35 - Parte B do FX3 Priorização e tratamento

ID	Controle existente	D	R	E	A	D	Média	Mitigação, camada e referências	Decisão
T-FX3-01	Rotas de cesta verificam autenticação e consultam a identidade no mapa de sessões. O logout limpa o estado no navegador.	8	7	6	7	7	7,0 Alto	Aplicar HTTPS fora do laboratório e sessão curta com revogação no servidor. Preferir cookie HttpOnly, Secure e SameSite para sessão no mesmo domínio, com defesa contra CSRF nas ações de escrita. Preventivo e corretivo / aplicação e rede. ASVS 7.3.2, 7.4.1, 12.2.1. Guia SESS. LGPD, art. 46.	Mitigar
T-FX3-02	O servidor associa o UserId à sessão e calcula preços e entrega com dados internos. O fluxo de leitura de cartão e endereço tem filtros próprios.	9	8	7	8	7	7,8 Alto	Consultar cesta e referências pela chave do objeto mais o titular da sessão. Recalcular valores no servidor, validar estoque e usar operação idempotente com compensação explícita para efeitos distribuídos entre SQLite, MarsDB e PDF. Preventivo / aplicação e dados. ASVS 2.3.1, 2.3.3, 8.2.2. Guia AUTHZ. LGPD, art. 46.	Mitigar

ID	Controle existente	D	R	E	A	D	Média	Mitigação, camada e referências	Decisão
T-FX3-03	Há confirmação com orderId e registro de horário, rota e status HTTP. O histórico mascara vogais do e-mail.	7	7	6	6	6	6,4 Médio	Emitir evento de pedido com ID interno do ator, orderId, cesta, chave de idempotência, horário e resultado. Enviar a trilha protegida sem número de cartão nem endereço completo. Detectivo e corretivo / aplicação e processo. ASVS 16.2.1, 16.2.5, 16.4.2. Guia LOG. LGPD, art. 46.	Mitigar
T-FX3-04	Middleware rejeita credencial malformada. O handler de erro devolve título detalhado.	4	9	9	6	8	7,2 Alto	Responder falhas de autenticação com erro genérico em JSON e ID de correlação. Conservar detalhes necessários em registro de acesso restrito e validar cabeçalhos da configuração implantada. Preventivo e detectivo / aplicação. ASVS 13.4.2, 13.4.6, 16.5.1. Guia ERR. LGPD, art. 46.	Mitigar
T-FX3-05	A rota requer sessão e cesta existente. O fluxo verifica estoque na inclusão de itens, com geração local de PDF no checkout.	7	6	7	8	7	7,0 Alto	Impor limite de concorrência, tempo e tamanho de pedido e PDF por conta. Separar a área de comprovantes, aplicar quota e política de retenção e alertar sobre falhas de escrita. Preventivo e detectivo / aplicação e operação. ASVS 2.4.1, 13.1.3, 14.2.7. Guia DOS. LGPD, art. 46.	Mitigar
T-FX3-06	O middleware exige JWT e injeta UserId no corpo. A consulta de cesta usa o id da URL como filtro de objeto.	8	10	8	8	8	8,4 Alto	Derivar UserId do contexto validado e incluí-lo no filtro da consulta com a chave de cesta. Aplicar a mesma política de titularidade às operações de itens e checkout. Preventivo / aplicação e dados. ASVS 8.2.2, 8.3.1. Guia IDOR. LGPD, art. 46.	Mitigar
T-FX3-07	Há restrições de formato e caminho no manipulador. O nome incorpora uma parte aleatória. V5 comprova a listagem de documentos de exemplo.	7	8	8	7	8	7,6 Alto	Guardar PDFs em área privada, desativar a listagem e entregar comprovantes por rota que verifique titularidade no servidor. Revisar e remover artefatos públicos já gerados. Preventivo e corretivo / aplicação e dados. ASVS 8.2.2, 13.4.3, 14.2.7. Guia AUTHZ. LGPD, art. 46.	Mitigar

Fonte: elaboração própria.

6.3.5 Justificativas e critérios de aceite

T-FX3-01 Reutilização de sessão de comprador

Evidência login.component.ts, request.interceptor.ts, navbar.component.ts e lib/insecurity.ts. JWT amostral sem exp na M1.

Dano (8) A sessão permite agir sobre a cesta e dados vinculados a uma conta.

Reprodutibilidade (7) O replay depende de capturar um token ainda aceito.

Explorabilidade (6) Primeiro é necessário acesso à credencial de sessão.

Usuários afetados (7) Cada token reutilizado afeta a conta à qual está vinculado.

Descoberta (7) O armazenamento e a ausência de exp nas amostras são verificáveis.

Aceite Após encerrar ou expirar uma sessão de teste, a mesma credencial deve falhar nas leituras e escritas de cesta.

T-FX3-02 Checkout de cesta alheia ou referências indevidas

Evidência routes/order.ts. O método procura a cesta por id e lê paymentId e addressId enviados no corpo.

Dano (9) A escrita pode alterar cestas, comprometer a integridade de pedidos e gerar disputa.

Reprodutibilidade (8) O código mostra o caminho, mas a alteração da cesta alheia não foi executada na M1.

Explorabilidade (7) Requer conta válida, objeto elegível e montagem do pedido.

Usuários afetados (8) A mesma condição pode afetar diferentes titulares se os IDs forem conhecidos.

Descoberta (7) A rota usa um identificador visível e o código indica onde é consumido.

Aceite Com duas contas sintéticas, negar o checkout com cesta, endereço ou cartão da outra conta. Reenviar o pedido autorizado deve produzir no máximo um pedido e um débito.

T-FX3-03 Contestação de pedido sem correlação de eventos

Evidência server.ts e routes/order.ts. Registro HTTP e coleção de pedido têm finalidades distintas.

Dano (7) A operação contestada pode exigir reversão e investigação manual.

Reprodutibilidade (7) As rotas repetem o mesmo formato de log.

Explorabilidade (6) É preciso existir um pedido e uma disputa de autoria.

Usuários afetados (6) O impacto incide nos titulares e pedidos sem correlação.

Descoberta (6) A lacuna aparece ao comparar registros de acesso e histórico.

Aceite Dois pedidos de teste devem ser localizados por orderId na trilha. Tentativas de alterar o evento pela conta do serviço devem falhar.

T-FX3-04 Erro de autorização com detalhes internos

Evidência V4. Authorization malformado na rota de cesta retornou HTML com framework e versão declarada.

Dano (4) A resposta evidencia tecnologia e versão, sem demonstrar acesso a dados de conta.

Reprodutibilidade (9) O T1 preservou requisição e corpo HTML da resposta.

Explorabilidade (9) Uma chamada com cabeçalho inválido é suficiente.

Usuários afetados (6) A informação descreve a instância e beneficia ataques posteriores.

Descoberta (8) O erro pode ser induzido diretamente na rota de cesta.

Aceite Um cabeçalho malformado deve devolver falha controlada sem versão, stack trace ou caminho interno.

T-FX3-05 Saturação por geração de comprovantes

Evidência routes/order.ts. O checkout produz PDF e grava no mesmo sistema de arquivos usado pela loja.

Dano (7) Recursos compartilhados tornam o checkout e o servidor suscetíveis a degradação.

Reprodutibilidade (6) O limiar de saturação depende da instância e não foi medido.

Explorabilidade (7) Uma conta válida permite iniciar checkouts, sob as condições do fluxo.

Usuários afetados (8) I/O e CPU são compartilhados com os demais compradores.

Descoberta (7) A geração de PDF e o armazenamento aparecem no caminho de compra.

Aceite Um ensaio local controlado deve respeitar as cotas e manter acessíveis as consultas legítimas quando o limite de geração for atingido.

T-FX3-06 Leitura da cesta de outro titular

Evidência V3. Uma conta autenticada consultou a cesta de outra e recebeu HTTP 200 com dados da cesta.

Dano (8) A resposta expõe itens e vínculo de usuário de outra conta.

Reprodutibilidade (10) O T1 confirmou a leitura com duas contas de teste e evidência HTTP.

Explorabilidade (8) Exige uma conta válida e um ID diferente.

Usuários afetados (8) Identificadores numéricos permitem repetir o cenário para outros titulares.

Descoberta (8) O ID aparece na rota e é verificável pela interface de rede.

Aceite Com JWT de A, uma leitura da cesta de B deve retornar 403 ou 404. A leitura da cesta de A deve continuar retornando apenas os dados autorizados.

T-FX3-07 Exposição de comprovante pelo diretório HTTP

Evidência V5 confirma o canal público /ftp/. routes/order.ts e routes/fileServer.ts ligam o PDF de pedido ao canal. A M1 não capturou um comprovante de terceiro.

Dano (7) O PDF pode associar o titular a uma compra e revelar seus itens.

Reprodutibilidade (8) O caminho aparece no código, mas o acesso a um recibo de terceiro não foi exercitado no T1.

Explorabilidade (8) Se listado ou obtido o nome, basta a requisição HTTP.

Usuários afetados (7) O conjunto exposto depende dos comprovantes existentes e da retenção.

Descoberta (8) O caminho de download aparece na interface e há listagem do diretório.

Aceite Acesso sem sessão ou com conta alheia deve falhar tanto pela rota autenticada quanto pelo endereço público antigo.

6.3.6 Conclusão do fluxo

A leitura confirmada torna prioritária a autorização por objeto. A mesma política precisa ser avaliada em itens, checkout e comprovantes, pois são caminhos distintos para dados do titular. Recalcular preços no servidor protege apenas uma parte da integridade da transação.

Mesmo com autorização por objeto, a consistência entre pedido, débito simulado, cesta e arquivo depende de idempotência e tratamento de falhas. O risco residual inclui roubo de sessão e falhas parciais entre armazenamentos. A verificação precisa cobrir repetição e concorrência.

6.4 FX4 ADMINISTRAÇÃO E CONTABILIDADE

A interface administrativa lista contas e feedbacks e permite moderação. A interface contábil consulta pedidos e envia a alteração de entrega. As duas usam sessão, mas as rotas adotam verificações distintas no servidor. O recorte compara essas diferenças.

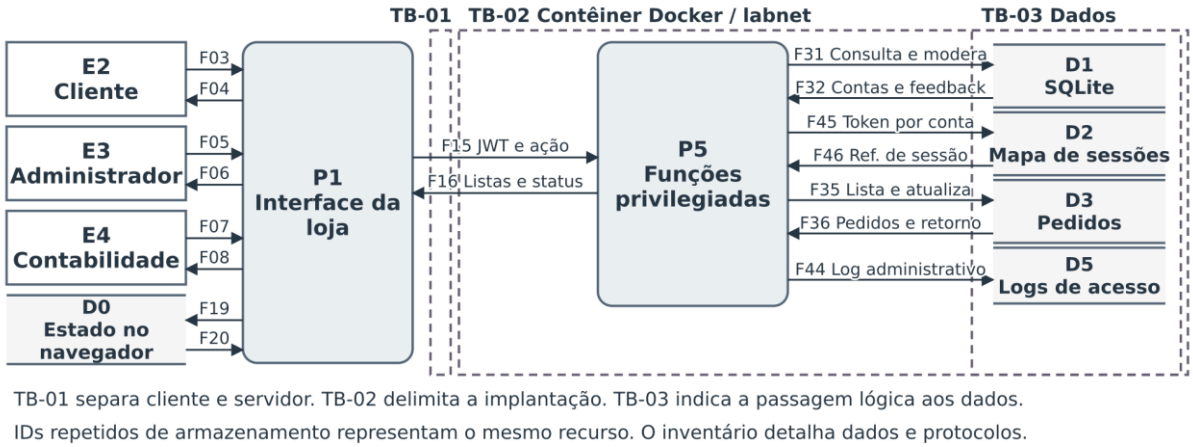
6.4.1 Ficha do fluxo

Quadro 36 - Identificação e condições do FX4

Campo	Descrição
ID e função	FX4 / Administração e contabilidade
Responsável e revisor propostos	João Victor Rodrigues Santos / Leonardo Pacheco B Dias
Ator e gatilho	Administrador E3 ao consultar ou moderar e operador E4 ao consultar pedidos ou registrar entrega. Cliente E2 é o papel usado para avaliar solicitações fora da permissão.
Pré-condições	Sessão válida e autorização administrativa ou contábil conforme a ação. Um pedido existente é necessário para conferir mudança efetiva de estado.
Resultado esperado	Consultas restritas ao papel e à finalidade. Moderação e transição de entrega com autoria registrada e alteração apenas do recurso autorizado.

Fonte: elaboração própria.

Figura 6 - Recorte do DFD do FX4



Fonte: elaboração própria.

Quadro 37 - Requisições e evidências do FX4

Método e rota	Base	Observação
GET /rest/user/authentication-details/ e GET /api/Users	Código e teste upstream	user.service.ts usa authentication-details/ para a listagem. GET /api/Users é rota direta alternativa. Extrato A4.

Método e rota	Base	Observação
GET /api/Users/:id, GET /api/Feedbacks e DELETE /api/Feedbacks/:id	Código v20.2.0	Consulta de detalhe, listagem pública utilizada pela SPA e exclusão. A proteção dessas ações difere.
GET /rest/order-history/orders e PUT /rest/order-history/:id/delivery-status	Código e teste upstream	routes/orderHistory.ts e teste order-history.test.ts. O projeto prevê accounting autorizado e customer/admin recusados.

Fonte: OWASP Juice Shop (2026), Silva *et al.* (2026) e elaboração própria.

Quadro 38 - Elementos percorridos no FX4

Nº	De	Para	Seta	Dados trafegados	Protocolo e formato	Fronteira
1	E2	P1	F03	Ações autenticadas de sessão, cesta e compra	Interface web / formulário	Sem travessia
2	P1	E2	F04	Perfil, itens, estado de compra e comprovante	Interface web / renderização	Sem travessia
3	E3	P1	F05	Consulta de usuários e moderação de feedback	Interface web / formulário	Sem travessia
4	P1	E3	F06	Listas e resultado da moderação	Interface web / renderização	Sem travessia
5	E4	P1	F07	Consulta de pedidos e comando de entrega	Interface web / formulário	Sem travessia
6	P1	E4	F08	Pedidos e estado de entrega	Interface web / renderização	Sem travessia
7	P1	P5	F15	JWT, consultas e comandos de moderação ou entrega	HTTP / JSON	TB-01 TB-02
8	P5	P1	F16	Dados de contas, feedbacks e pedidos, resultado das operações	HTTP / JSON	TB-01 TB-02
9	P1	D0	F19	JWT, cookie e ID da cesta	Web Storage / cookie	Sem travessia
10	D0	P1	F20	JWT e ID da cesta para requisições	Web Storage / cookie	Sem travessia
11	P5	D1	F31	Consulta de contas e feedbacks ou exclusão de feedback	Sequelize / SQL local	TB-03
12	D1	P5	F32	Linhas consultadas ou resultado da exclusão	Sequelize / SQL local	TB-03
13	P5	D3	F35	Consulta de pedidos ou alteração da entrega por ID	MarsDB / documento em memória	TB-03
14	D3	P5	F36	Pedidos e resultado de atualização	MarsDB / documento em memória	TB-03

Nº	De	Para	Seta	Dados trafegados	Protocolo e formato	Fronteira
15	P5	D5	F44	Método, URL, horário, origem e status de operações privilegiadas	Escrita local / log HTTP	TB-03
16	P5	D2	F45	Consulta do token associado a cada conta listada	Acesso em memória	TB-03
17	D2	P5	F46	Referência à sessão e horário declarado de emissão	Acesso em memória	TB-03

Fonte: elaboração própria.

Quadro 39 - Classificação dos dados no FX4

Dado	Classificação	Localização	CID crítica
E-mail, ID, papel e metadados de sessão	Dado pessoal quando identificável, papel interno	F15, F16, D1 e D2	Confidencialidade
Feedback, nota e vínculo de autoria	Público na exibição autorizada e dado pessoal se identificável	F16, F31, F32 e D1	Integridade
Pedido, referências e status de entrega	Dado pessoal quando vinculável e estado interno	F15, F16, D3, F35 e F36	Integridade
Token de administrador ou de contabilidade	Credencial ou segredo	D0 e F15	Confidencialidade
Metadados da operação	Interno e dado pessoal quando vinculável	F44 e D5	Integridade

Fonte: Brasil (2018), OWASP Juice Shop (2026) e elaboração própria.

Quadro 40 - Controles identificados no FX4

Controle	Elemento	Base de constatação
Guarda de rota Angular	P1	app.guard.ts e configuração de rotas. Controla navegação na interface.
Autenticação nas listagens de contas e na exclusão de feedback	P5 e F15	server.ts. As rotas listadas usam isAuthorized.
Filtro de papel na contabilidade	P5 e F15	isAccounting em lib/insecurity.ts. Teste upstream documenta permissões esperadas.
Mascaramento ou exclusão de segredos	P5 e F16	routes/authenticatedUsers.ts e configuração de User no server.ts.

Fonte: OWASP Juice Shop (2026) e Silva *et al.* (2026).

6.4.2 Matriz STRIDE por elemento

Os códigos NA1 a NA13 remetem às justificativas do Apêndice A. Cada célula preenchida vincula uma ameaça do FX4 ou registra N/A para a categoria aplicável ao tipo. O detalhamento das setas consta do quadro de percurso.

Quadro 41 - Matriz STRIDE do FX4

Elemento	S	T	R	I	D	E
D0 Estado no navegador		N/A 11		N/A 11	N/A 10	
D1 SQLite		N/A 7		N/A 7	N/A 6	
D2 Mapa de sessões		N/A 7		N/A 7	N/A 6	
D3 Pedidos		T-FX4-02		N/A 7	T-FX4-05	
D5 Logs de acesso		N/A 9	T-FX4-03	N/A 9	N/A 9	
E2 Cliente	N/A 1		N/A 1			
E3 Administrador	N/A 1		T-FX4-03			
E4 Contabilidade	T-FX4-01		T-FX4-03			
P1 Interface da loja	T-FX4-01	N/A 13	N/A 8	T-FX4-04	N/A 10	N/A 8
P5 Funções privilegiadas	T-FX4-01	T-FX4-02	T-FX4-03	T-FX4-04	T-FX4-05	T-FX4-06
F03		N/A 13		N/A 13	N/A 6	
F04		N/A 13		N/A 13	N/A 6	
F05		N/A 13		N/A 13	N/A 6	
F06		N/A 13		N/A 13	N/A 6	
F07		N/A 13		N/A 13	N/A 6	
F08		N/A 13		N/A 13	N/A 6	
F15		T-FX4-02		N/A 4	T-FX4-05	
F16		N/A 3		T-FX4-04	T-FX4-05	
F19		N/A 11		N/A 11	N/A 6	
F20		N/A 11		N/A 11	N/A 6	
F31		N/A 3		N/A 4	N/A 6	
F32		N/A 3		T-FX4-04	N/A 6	
F35		T-FX4-02		N/A 4	T-FX4-05	
F36		N/A 3		N/A 4	T-FX4-05	
F44		N/A 9		N/A 9	N/A 6	
F45		N/A 3		N/A 4	N/A 6	
F46		N/A 3		T-FX4-04	N/A 6	

Fonte: elaboração própria.

6.4.3 Questionário do fluxo

Compreensão do fluxo

Q1 FX4 dá acesso a conjuntos de dados e ações que não pertencem ao comprador comum. Uma falha em P5 pode transformar uma sessão de cliente em capacidade de consultar contas ou remover feedbacks.

Q2 E3 é o papel previsto para administração. E4 é o papel exigido para consulta contábil e entrega. No código, admin não implica accounting. E2 representa o usuário que tenta chamar diretamente uma rota fora da sua permissão.

Q3 F05 ou F07 aciona P1. F15 e F16 levam JWT, IDs, comandos e listas via HTTP e JSON. P5 consulta D1 por F31 e F32, D2 por F45 e F46 e D3 por F35 e F36. F44 envia metadados a D5.

Q4 F15 e F16 cruzam TB-01 e TB-02 e precisam de autorização na API. F31, F32, F35, F36, F44, F45 e F46 cruzam TB-03, onde o acesso se converte em consulta ou gravação de alcance coletivo.

Q5 F16 pode conter dados de identificação, feedback e pedidos. O JWT é credencial. D1 guarda conta e feedback, D2 conserva o mapa de sessão e D3 o pedido e entrega. Não se identificou categoria sensível por definição legal no esquema examinado.

Q6 As telas usam fragmentos Angular e chamam rotas HTTP independentes. Cabeçalho Authorization, IDs de feedback e pedido e campo deliveryStatus são entradas. As rotas privilegiadas compõem superfície administrativa mesmo quando a SPA esconde a navegação.

Q7 A SPA tem guardas por papel. O servidor usa isAccounting nas rotas contábeis. As rotas de listagem de usuários e exclusão de feedback verificam JWT, sem o mesmo teste de papel. As listagens filtram ou mascaram alguns campos.

Spoofing

S1 P5 verifica o token nas rotas protegidas. A contabilidade usa assinatura e claim de papel. As consultas a D1, D2 e D3 usam permissões do próprio processo.

S2 O JWT vem de FX1 e o interceptor o envia em F15. isAccounting chama o verificador de assinatura e lê o papel do token. Não se identificou consulta ao papel atual ou invalidação no percurso estudado.

S3 T-FX4-01 trata sessão antiga de E4 após mudança de acesso. T-FX1-06 é uma dependência compartilhada quando a confiança no emissor é quebrada.

Tampering

T1 O cliente pode modificar o campo deliveryStatus e IDs antes de F15. A alteração de D3 é executada em P5 e a exclusão de feedback muda D1.

T2 A contabilidade verifica accounting, mas calcula o novo estado pela inversão do valor no corpo sem comparar o estado persistido. A exclusão de feedback requer autorização de função além de identificação do item.

T3 O JWT assinado protege claims contra edição quando o verificador e a chave são confiáveis. O comando HTTP não tem assinatura própria e o fluxo usa HTTP local. A integridade de entrega depende da validação de transição.

Repudiation

R1 F44 registra a requisição HTTP. Não se identificou trilha específica associando o ator validado à exclusão, ao documento de pedido e ao estado anterior e posterior.

R2 D5 é local com rotação. Não se identificaram garantias de integridade da trilha nem proteção contra alteração por conta com acesso ao arquivo.

R3 Um administrador ou contador pode negar autoria de ação em T-FX4-03 se a trilha não correlacionar identidade, alvo, ação e resultado.

Information Disclosure

I1 A listagem em F16 devolve dados de várias contas. authentication-details mascara password e totpSecret, mas espalha os demais campos do modelo. GET /api/Users exclui esses segredos, sem exigir admin.

I2 O painel precisa de um conjunto restrito de campos para identificar a conta e seu estado. Respostas amplas e pedidos completos aumentam a exposição sem finalidade demonstrada para cada campo.

I3 O transporte no laboratório é HTTP. Os campos mascarados oferecem redução pontual e não protegem a resposta inteira. A configuração examinada não demonstrou criptografia de D1 ou D5 em repouso.

Denial of Service

D1 Listas amplas ocupam memória e CPU para consulta e serialização. A consulta da coleção de pedidos usa find() e reverse() no caminho analisado.

D2 Os trechos de listagem não implementam paginação no servidor para as chamadas estudadas. A tabela da SPA pode paginar após receber toda a lista. As hipóteses de saturação ficaram sem medição.

D3 O recorte usa API, SQLite, mapa em memória e MarsDB locais. O tratamento de falhas em integrações externas não foi analisado em FX4.

Elevation of Privilege

E1 A API contábil verifica papel no servidor. AdminGuard protege navegação, e isAuthorized valida autenticação nas ações administrativas examinadas. Cada operação precisa de permissão de função e, quando aplicável, de recurso.

E2 Em análise estática, uma conta comum pode tentar acessar dados de usuários e remover feedback por chamadas diretas. T-FX4-04 e T-FX4-06 descrevem o efeito e o teste proposto, sem confirmação local na M1.

E3 A identidade do contêiner é compartilhada e não substitui a separação de deveres entre E3 e E4. As permissões devem ser específicas para consultar contas, moderar e alterar entrega.

Fechamento do fluxo

V1 T-FX4-04 tem média 8,6, pois a listagem pode expor dados de várias contas em uma chamada. T-FX4-06 tem média 8,2 e envolve uma mudança indevida de estado.

V2 Não houve achado confirmado na M1 diretamente neste fluxo. V1, V2 e V6 ajudam a explicar dependências do token, mas não provam os efeitos específicos em P5.

V3 A validação proposta cruza os papéis customer, deluxe, admin e accounting em cada rota. Restam verificar rebaixamento de conta, mudança concorrente de entrega e disponibilidade com coleções crescentes.

6.4.4 Registro de ameaças

Quadro 42 - Parte A do FX4 Identificação das ameaças

ID e elementos principais	STRIDE e propriedade	Cenário	CWE e OWASP 2021	Status
T-FX4-01 P5, E4, P1	S / Autenticidade	Um ex-operador de contabilidade pode tentar apresentar em F15 um JWT emitido antes de perder acesso. P5 baseia a identidade contábil na assinatura e no papel transportado pelo token, permitindo que uma sessão antiga ainda represente E4 se o token continuar aceito.	CWE-613 A07	Plausível
T-FX4-02 P5, D3, F15	T / Integridade	Um operador E4 pode enviar em F15 um estado anterior incorreto ou desatualizado. P5 inverte o valor recebido e grava em D3 sem comparar com a versão persistida. Com isso, pode desfazer uma atualização legítima ou produzir uma transição que não corresponde ao estado real.	CWE-345, CWE-841 A04	Plausível

ID e elementos principais	STRIDE e propriedade	Cenário	CWE e OWASP 2021	Status
T-FX4-03 D5, P5, E3	R / Não repúdio	Um administrador E3 ou operador E4 pode contestar a exclusão de um feedback ou uma alteração de entrega. F44 e D5 registram o acesso HTTP, porém não preservam de forma associada autor validado, estado anterior e resultado da ação.	CWE-778 A09	Plausível
T-FX4-04 F16, P1, P5	I / Confidencialidade	Um comprador com JWT válido pode chamar diretamente P5 por F15 e tentar obter a lista de usuários em F16. O servidor verifica autenticação sem conferir o papel administrativo, expondo dados de contas, como e-mails e papéis, fora da finalidade da sessão.	CWE-862, CWE-200 A01	Plausível
T-FX4-05 P5, F15, F16	D / Disponibilidade	Um operador E4 pode repetir a listagem integral de pedidos em P5 e D3. À medida que a coleção cresce, leitura, ordenação inversa e serialização podem ocupar memória e CPU, degradando o atendimento aos demais usuários.	CWE-400 A04	Plausível
T-FX4-06 P5	E / Autorização	Um comprador com JWT válido pode tentar excluir um feedback em P5 enviando o ID pelo fluxo F15. A rota protegida apenas por autenticação pode aceitar uma função reservada e remover de D1 um registro que a conta não tem permissão de moderar.	CWE-862, CWE-285 A01	Plausível

Fonte: elaboração própria.

D, R, E, A e D indicam dano, reprodutibilidade, explorabilidade, usuários afetados e descoberta. Os números de controle pertencem ao ASVS 5.0.0. Os códigos de guias da OWASP remetem ao Apêndice A.

Quadro 43 - Parte B do FX4 Priorização e tratamento

ID	Controle existente	D	R	E	A	D	Média	Mitigação, camada e referências	Decisão
T-FX4-01	Existe verificação de assinatura e papel accounting no servidor para as duas rotas de pedido.	8	7	6	7	7	7,0 Alto	Consultar estado e papel atual nas ações de contabilidade, revogar imediatamente as sessões de conta desativada ou rebaixada e validar as claims temporais. Preventivo e corretivo / aplicação. ASVS 7.4.2, 8.3.2, 9.2.1. Guia SESS. LGPD, art. 46.	Mitigar

ID	Controle existente	D	R	E	A	D	Média	Mitigação, camada e referências	Decisão
T-FX4-02	A rota exige papel accounting. A atualização seleciona o documento pelo _id.	7	8	7	7	7	7,2 Alto	Receber estado de destino e versão esperada, validar transições permitidas e aplicar atualização condicional atômica no documento. Informar conflito quando a versão divergir ou 404 quando o pedido não existir. Preventivo e detectivo / aplicação e dados. ASVS 2.3.1, 2.3.3. Guia BIZ. LGPD, art. 46.	Mitigar
T-FX4-03	Há registro de horário, rota, método e status na camada HTTP.	7	7	7	7	6	6,8 Médio	Gravar auditoria com ator, papel efetivo, recurso, valores pertinentes antes e depois, decisão de autorização e horário. Separar o destino e proteger escrita e retenção. Detectivo e corretivo / aplicação e processo. ASVS 16.2.1, 16.3.2, 16.4.2, 16.4.3. Guia LOG. LGPD, art. 46.	Mitigar
T-FX4-04	authentication-details mascara password e totpSecret. GET /api/Users os exclui. O AdminGuard limita a navegação na SPA.	8	9	8	9	9	8,6 Alto	Exigir permissão explícita de leitura de contas no servidor, limitar campos à finalidade da tela e paginar o resultado. Registrar consultas privilegiadas. Preventivo / aplicação e dados. ASVS 8.2.1, 8.2.3, 8.3.1, 14.2.6. Guia AUTHZ. LGPD, art. 46.	Mitigar
T-FX4-05	A rota exige o papel accounting e usa uma coleção em memória. A consulta não tem paginação no trecho analisado.	7	6	6	8	7	6,8 Médio	Implementar paginação no servidor com tamanho máximo, consulta por filtros e limite por identidade. Medir latência e tamanho da resposta por rota. Preventivo e detectivo / aplicação e dados. ASVS 2.4.1, 13.1.3. Guia DOS. LGPD, art. 46.	Mitigar
T-FX4-06	A guarda da SPA restringe a tela de administração. A rota requer JWT, e o PUT possui bloqueio específico.	8	8	8	8	9	8,2 Alto	Exigir permissão de moderação na rota DELETE, negar por padrão e registrar autor e recurso. Controlar reversão ou retenção de moderação conforme a finalidade do feedback. Preventivo e detectivo / aplicação. ASVS 8.2.1, 8.3.1, 16.3.2. Guia AUTHZ. LGPD, art. 46.	Mitigar

Fonte: elaboração própria.

6.4.5 Justificativas e critérios de aceite

T-FX4-01 Reuso de sessão contábil após desligamento

Evidência lib/insecurity.ts e routes/orderHistory.ts. isAccounting verifica assinatura e papel. A verificação observada no código não consulta estado atual da conta.

Dano (8) A sessão contábil expõe pedidos e permite mudar estado de entrega.

Reprodutibilidade (7) O efeito exige token emitido e mudança de acesso, sequência não testada.

Explorabilidade (6) O agente precisa ter retido um token contábil utilizável.

Usuários afetados (7) O papel alcança mais pedidos do que uma sessão comum.

Descoberta (7) A implementação da verificação permite identificar as claims usadas.

Aceite Obter token com papel accounting, remover esse papel em ambiente de teste e confirmar que o mesmo token deixa de ler ou atualizar pedidos.

T-FX4-02 Atualização de entrega baseada em estado do cliente

Evidência routes/orderHistory.ts, toggleDeliveryStatus. O valor gravado deriva de !req.body.deliveryStatus.

Dano (7) Um pedido pode figurar como entregue ou em trânsito no momento errado.

Reprodutibilidade (8) O caminho é determinístico quando o corpo diverge do registro real.

Explorabilidade (7) Requer sessão contábil e identificador do pedido.

Usuários afetados (7) Cada gravação afeta o pedido escolhido, com repetição possível.

Descoberta (7) O corpo e a atribuição podem ser conferidos no código da versão.

Aceite Duas alterações concorrentes com a mesma versão devem produzir no máximo um sucesso. Versão velha, estado inválido e ID ausente devem ser rejeitados.

T-FX4-03 Repúdio de moderação e entrega

Evidência server.ts, Morgan combined, e handlers de feedback e pedido. Não foi identificada trilha de antes e depois para o escopo.

Dano (7) A falta de atribuição dificulta responsabilização e correção de pedidos e feedbacks.

Reprodutibilidade (7) As ações selecionadas passam pelo mesmo registro HTTP.

Explorabilidade (7) O agente precisa praticar ou contestar uma ação em investigação.

Usuários afetados (7) As duas operações podem atingir recursos de vários titulares.

Descoberta (6) A deficiência depende da inspeção do registro e da rota.

Aceite Excluir um feedback de teste e alterar entrega deve gerar eventos distintos e íntegros. Credenciais e corpo integral de pedidos devem ficar fora da trilha.

T-FX4-04 Consulta de usuários por conta comum

Evidência server.ts, authenticatedUsers.ts e user.service.ts. A listagem da interface chama authentication-details. Essa rota e GET /api/Users usam isAuthorized sem checagem de admin.

Dano (8) A lista reúne dados identificáveis de várias contas.

Reprodutibilidade (9) A rota e o middleware são conhecidos, com confirmação local ainda pendente.

Explorabilidade (8) Uma sessão comum e cliente HTTP bastariam no cenário descrito.

Usuários afetados (9) Uma única listagem pode alcançar diversos titulares.

Descoberta (9) A interface administrativa revela a rota de listagem em suas chamadas.

Aceite Token de cliente ou contabilidade sem permissão deve receber 403. A resposta autorizada deve conter apenas os campos permitidos.

T-FX4-05 Listagem administrativa sem limite de volume

Evidência routes/orderHistory.ts, allOrders chama find() e reverse() sem paginação. O acesso requer accounting.

Dano (7) A pressão sobre o processo compartilhado pode afetar atendimento e back-office.

Reprodutibilidade (6) O limiar depende de volume e concorrência, que não foram ensaiados.

Explorabilidade (6) É necessária sessão contábil e uma coleção com volume significativo.

Usuários afetados (8) O servidor de pedidos também atende outros fluxos da loja.

Descoberta (7) É possível identificar listagem integral pelo método da rota.

Aceite Com massa sintética crescente, o tamanho máximo da página deve ser respeitado e uma consulta legítima simultânea deve continuar atendida.

T-FX4-06 Exclusão de feedback por conta sem papel administrativo

Evidência server.ts e administration.component.ts. DELETE /api/Feedbacks/:id passa por isAuthorized e pelo recurso gerado. A M1 não testou essa ação.

Dano (8) A exclusão pode adulterar a percepção do catálogo e retirar manifestações de terceiros.

Reprodutibilidade (8) A hipótese foi localizada em código. O efeito não foi reproduzido na M1.

Explorabilidade (8) Uma conta comum e o ID de feedback seriam suficientes no cenário.

Usuários afetados (8) O mesmo controle protege a operação para todos os feedbacks.

Descoberta (9) O endpoint é usado pela interface e identificável no código.

Aceite Em instância de teste, cliente sem permissão recebe 403 e o feedback permanece. Operador autorizado pode moderar e a trilha registra a decisão.

6.4.6 Conclusão do fluxo

A diferença entre as guardas administrativas e contábeis mostra onde colocar o controle. O servidor deve definir permissões de leitura de contas e moderação e verificar ambas nas rotas correspondentes. O papel contábil precisa de estado de sessão atualizado e validação de transição de entrega.

O risco residual inclui abuso por operador autorizado e inconsistência em escritas concorrentes. Auditoria protegida, segregação de funções e atualização condicional reduzem esses efeitos e permitem investigar incidentes.

7 VISÃO CONSOLIDADA

7.1 DEZ AMEAÇAS PRIORITÁRIAS

A ordenação agrega os 25 cenários com o mesmo critério. Das 25 ameaças, 18 atingiram risco alto e sete, risco médio. Sete registros se apoiam em seis achados da M1. O sétimo achado histórico, V5, fundamenta a exposição do canal de arquivos, enquanto a leitura de um comprovante de pedido permanece plausível. A maior pontuação, 9,8, é da injeção no login. A segunda, 9,0, corresponde à hipótese de atribuição de papel privilegiado no cadastro. O status acompanha a média porque uma evidência observada e uma hipótese podem receber valores próximos e exigir verificações distintas.

A consulta de usuários e a moderação de feedback requerem permissão de função. A cesta e o comprovante requerem permissão sobre o objeto. Parametrizar a autenticação corrige o mecanismo de injeção, mas as falhas de acesso ainda precisam de autorização no ponto que lê ou altera o recurso. O controle de sessão é compartilhado, e a implementação proposta deve ser verificada nas rotas que usam mecanismos distintos. A retenção e a minimização entram tanto no token e na resposta da API quanto na trilha de auditoria.

Quadro 44 - Top 10 por média DREAD e ordem de tratamento

Nº	ID	Cenário e elemento principal	DREAD	Status	Frente do plano
1	T-FX1-02	Injeção SQL na autenticação (P2)	9,8	T1 V1	1
2	T-FX2-06	Atribuição de papel privilegiado no cadastro (P3)	9,0	Plausível	2
3	T-FX2-01	Tomada de conta por resposta previsível (P3)	8,8	T1 V7	2
4	T-FX1-04	Hash de senha no JWT (F10)	8,6	T1 V2	1
5	T-FX4-04	Consulta de usuários por conta comum (F16)	8,6	Plausível	3
6	T-FX3-06	Leitura da cesta de outro titular (P4)	8,4	T1 V3	3
7	T-FX1-06	Chave de assinatura distribuída (P2)	8,4	Plausível	1
8	T-FX4-06	Exclusão de feedback por conta sem papel administrativo (P5)	8,2	Plausível	3
9	T-FX1-01	Tentativas repetidas no login (P2)	8,0	T1 V6	4
10	T-FX3-02	Checkout de cesta alheia ou referências indevidas (P4)	7,8	Plausível	3

Fonte: elaboração própria.

7.2 DISTRIBUIÇÃO POR CATEGORIA E ELEMENTO

Cada cenário é contado uma vez por categoria principal e uma vez pelo primeiro elemento do registro. Um cenário que aparece em várias células da matriz continua sendo um único registro. A distribuição não mede a severidade de um tipo de elemento por quantidade.

Quadro 45 - Distribuição STRIDE por fluxo

Fluxo	S	T	R	I	D	E	Total
FX1	1	1	1	1	1	1	6
FX2	1	1	1	1	1	1	6
FX3	1	1	1	2	1	1	7

Fluxo	S	T	R	I	D	E	Total
FX4	1	1	1	1	1	1	6
Total	4	4	4	5	4	4	25

Fonte: elaboração própria.

Quadro 46 - Distribuição por elemento principal do DFD

Elemento	Tipo	Ameaças
D5 / Logs de acesso	Armazenamento	4
P3 / Cadastro e recuperação	Processo	4
P4 / Cesta e pedido	Processo	4
P5 / Funções privilegiadas	Processo	4
P2 / Identidade e sessão	Processo	3
D2 / Mapa de sessões	Armazenamento	1
F10 / JWT, ID de cesta, perfil e erros	Fluxo	1
F12 / Confirmações de cadastro, pergunta e resultado do reset	Fluxo	1
F14 / Cesta, meios de pagamento, resultado e confirmação de pedido	Fluxo	1
F16 / Dados de contas, feedbacks e pedidos, resultado das operações	Fluxo	1
P6 / Arquivos HTTP	Processo	1

Fonte: elaboração própria.

Dos cenários, 16 têm processo como elemento principal, 5 têm armazenamento e 4 têm seta. A concentração em processos reflete a localização de decisões de autenticação, autorização e tratamento de dados.

7.3 PLANO DE MITIGAÇÃO

O plano agrupa cenários com causas ou controles compartilhados. Os grupos de autenticação, cadastro e autorização precedem as medidas de contenção porque alteram a identidade, o papel ou a titularidade usada nas demais verificações. Os controles de auditoria podem começar em paralelo para preservar evidências durante o tratamento.

Quadro 47 - Frentes de tratamento e critérios de aceite

Frente	Área e ameaças	Tratamento	Aceite
1	Autenticação, emissão e segredos T-FX1-02, 04 e 06	Parametrizar consulta, restringir claims, migrar hash de senha e rotacionar chave com revogação de JWT antigo.	A entrada V1 falha. Nenhum JWT ou retorno de perfil contém hash. Chaves antigas são rejeitadas.
2	Cadastro e recuperação T-FX2-06, 01, 02 e 04	Atribuir papel no servidor, substituir pergunta por recuperação de uso único e uniformizar respostas. Remover o vínculo público baseado em UserId.	Cadastro força customer. Reset não enumera contas e token de recuperação não pode ser reutilizado.
3	Autorização em P4 e P5 T-FX4-04 e 06, T-FX3-06, 02 e 07	Adotar política de função nas rotas privilegiadas e política de titularidade em cesta, pedido, endereço, pagamento e comprovante.	Matriz de papéis nega chamadas indevidas. Duas contas não acessam nem alteram recursos uma da outra.
4	Ciclo de sessão e contenção T-FX1-01 e 05, T-FX3-01, T-FX4-01, T-FX2-05	Aplicar limites por conta e origem, expiração efetiva, revogação e validação atual de papéis. Tratar sessões e capacidade de armazenamento.	Replay após logout, expiração ou rebaixamento falha. Amostra com abuso controlado preserva operação legítima.
5	Integridade e disponibilidade de pedidos T-FX3-02 e 05, T-FX4-02 e 05	Introduzir idempotência, controle de versão, quota de PDF, paginação e procedimento de compensação em falhas parciais.	Reenvio não duplica pedido. Escrita concorrente é detectada e listagens respeitam o limite.
6	Auditoria e retorno de erros T-FX1-03, T-FX2-03, T-FX3-03 e 04, T-FX4-03	Centralizar eventos de autenticação, reset, compra e ações privilegiadas em trilha protegida. Remover versão e detalhes de erro do cliente.	Eventos correlacionáveis com dados mínimos. Resposta de falha sem detalhe interno.

Fonte: elaboração própria.

8 VALIDAÇÃO E LIMITAÇÕES

8.1 CONFERÊNCIA DOCUMENTAL E HISTÓRICA

A conferência comparou os pontos de entrada dos diagramas com server.ts e com os serviços da SPA. Na M1, os pares HTTP sustentam a SQL injection de login, a presença de hash no JWT, a leitura de cesta alheia, o erro verboso, a listagem em /ftp/, a sequência de falhas de autenticação e o reset com resposta previsível. O Apêndice B reúne capturas e extratos com valores de credenciais omitidos. As Figuras 7 a 11 são históricas. As verificações de checkout completo e de administração foram reconstruídas pelo código e pelos testes publicados na tag.

A leitura de dois JWTs históricos encontrou alg RS256 e as chaves data, bid e iat, sem exp. Na distribuição oficial inspecionada, jsonwebtoken 0.4.0 grava exp quando recebe expiresInMinutes. O código da aplicação fornece expiresIn. O prazo de oito horas configurado no cookie pela SPA tampouco demonstra validade no servidor. A análise conserva essas evidências separadas para que um novo teste possa verificar expiração por rota.

Os cabeçalhos de V7 diminuem de 99 para 95 nas cinco solicitações de reset. O último retorno foi HTTP 200, seguido de login com a nova senha. O teste negativo de associação duplicada recebeu HTTP 400. A primeira evidência demonstra que a cota não impediu um palpite correto nessa amostra. A segunda restringe a hipótese de adulteração às condições em que ainda exista uma associação elegível ou insuficientemente protegida. O comportamento após a cota e a influência de proxy seguem em aberto.

A validação estrutural verificou identificadores e tipos, ligação de setas a processos, consistência entre os níveis do DFD, presença de fronteira em cada recorte, correspondência das matrizes com os registros e presença de 28 respostas por fluxo. O ranking foi recalculado a partir das cinco notas de cada cenário. Essas verificações tratam da coerência do modelo e do vínculo com suas fontes.

8.2 REVISÃO CRUZADA ENTRE INTEGRANTES

O quadro a seguir distribui uma revisão independente da pessoa indicada para cada recorte. O revisor deve conferir rotas e fronteiras na versão, testar a compatibilidade da ameaça com o papel do agente, verificar evidência e status e recalcular a pontuação. A revisão

deve registrar o resultado e as correções por fluxo. A confirmação individual permanece pendente.

Quadro 48 - Revisão cruzada por fluxo

ID	Responsável proposto	Revisor proposto	Situação
FX1	Diego Fonseca da Silva	Gustavo Gonçalves Trindade	A confirmar pela equipe
FX2	Leonardo Pacheco B Dias	Diego Fonseca da Silva	A confirmar pela equipe
FX3	Gustavo Gonçalves Trindade	João Victor Rodrigues Santos	A confirmar pela equipe
FX4	João Victor Rodrigues Santos	Leonardo Pacheco B Dias	A confirmar pela equipe

Fonte: elaboração própria.

8.3 LIMITAÇÕES E VERIFICAÇÕES PENDENTES

A base de observação direta corresponde aos artefatos da M1, complementada pela reexecução do laboratório em 8 de novembro de 2026. Nessa execução complementar, a equipe reproduziu na instância local os cenários de injeção no login, leitura de cesta de outro titular, listagem anônima de diretório, consulta da pergunta de segurança por e-mail e cota do reset de senha, além do cadastro com atribuição de papel privilegiado (T-FX2-06), antes classificado como plausível; as novas capturas constam do Apêndice B.5. A análise estática sustenta o percurso funcional de checkout, moderação e contabilidade, mas não documenta o resultado em uma nova execução da imagem do laboratório. Também não houve ensaio de carga, expiração, revogação ou concorrência, nem avaliação de todas as rotas privilegiadas. O digest, a rede e a porta da M1 são evidências da implantação histórica.

A próxima conferência no laboratório deve registrar, com dados fictícios, criação de conta e recuperação, checkout e download de comprovante, e chamadas administrativas por papel. Os testes de autorização devem usar duas contas de cliente e os papéis admin e accounting. A coleta deve preservar método, rota, status, versão e papel, omitir credenciais e distinguir chamadas permitidas das recusadas. Para mitigações de disponibilidade, critérios numéricos de capacidade dependem de medição na instância. A DREAD ordena cenários no recorte, sem estimar frequência de incidentes ou exposição em produção.

9 CONCLUSÃO

A análise localizou quatro funções nas quais uma decisão do servidor tem efeito direto sobre conta, cesta, pedido ou operação privilegiada. O uso de DFD e STRIDE por elemento mostrou que as evidências da M1 se concentram em pontos diferentes. A SQL injection altera a consulta que determina a identidade. O hash exposto decorre da serialização da conta no JWT. A leitura de cesta alheia ocorre depois que a sessão já foi aceita. A recuperação combina uma pergunta publicamente consultável com uma prova previsível. Essas diferenças determinam o controle e o teste adequados para cada caso.

A prioridade é corrigir a autenticação, limitar o material emitido na sessão e impedir que o cadastro público atribua funções reservadas. A correção do controle de acesso deve alcançar as APIs administrativas, as referências do checkout e a entrega de comprovantes. As medidas de auditoria, contenção e idempotência completam o tratamento ao reduzir contestação, degradação e efeitos de escritas repetidas.

O modelo registra 25 cenários, explicita os resultados observados na M1 e separa as hipóteses que ainda precisam de evidência de laboratório. Os critérios de aceite permitem conferir as medidas propostas com contas de teste e o mesmo conjunto de rotas. A revisão cruzada e a validação funcional das hipóteses são as próximas verificações que podem alterar o status ou a prioridade dos cenários.

REFERÊNCIAS

ALVES, Luis Fernando *et al.* Modelagem de ameaças com STRIDE e DREAD: uma análise preliminar aplicada a um sistema IoT. *In:* ESCOLA REGIONAL DE ENGENHARIA DE SOFTWARE, 8., 2024. **Anais [...]**. Porto Alegre: Sociedade Brasileira de Computação, 2024. p. 218-227. DOI 10.5753/eres.2024.4319. Disponível em: https://sol.sbc.org.br/index.php/eres/article/download/31855/31657/. Acesso em: 8 nov. 2026.

BRASIL. **Lei nº 13.709, de 14 de agosto de 2018**. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 8 nov. 2026.

CARNEIRO, Cinara Gomes de Melo; KUDO, Taciana Novo; BULCÃO NETO, Renato de Freitas. Um método para transformação de requisitos legais em padrões de requisitos de software: um estudo com a LGPD. *In:* CONGRESSO IBERO-AMERICANO EM ENGENHARIA DE SOFTWARE, 27., 2024, Curitiba. **Anais [...]**. Porto Alegre: Sociedade Brasileira de Computação, 2024. p. 348-355. DOI 10.5753/cibse.2024.28460. Disponível em: https://sol.sbc.org.br/index.php/cibse/article/download/28460/28270/. Acesso em: 8 nov. 2026.

DOCKER. **Docker Engine networking**. Seções Bridge network driver e Port publishing and mapping. *[S. l.]*: Docker, [s. d.]. Disponível em: https://docs.docker.com/engine/network/drivers/bridge/ e https://docs.docker.com/engine/network/port-publishing/. Acesso em: 8 nov. 2026.

HERNAN, Shawn *et al.* Uncover security design flaws using the STRIDE approach. **MSDN Magazine**, nov. 2006. Disponível em: https://learn.microsoft.com/en-us/archive/msdn-magazine/2006/november/uncover-security-design-flaws-using-the-stride-approach. Acesso em: 8 nov. 2026.

MANADHATA, Pratyusa K.; WING, Jeannette M. An attack surface metric. **IEEE Transactions on Software Engineering**, v. 37, n. 3, p. 371-386, 2011. DOI 10.1109/TSE.2010.60. Disponível em: https://manadhata.github.io/pdf/tse11.pdf. Acesso em: 8 nov. 2026.

MEIER, J. D. *et al.* Threat modeling. *In:* MEIER, J. D. *et al.* **Improving web application security: threats and countermeasures**. *[S. l.]*: Microsoft, 2003. cap. 3. Disponível em: https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648644(v=pandp.10). Acesso em: 8 nov. 2026.

MITRE. **Common Weakness Enumeration**. *[S. l.]*: MITRE, [s. d.]. Disponível em: https://cwe.mitre.org/. Acesso em: 8 nov. 2026.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). **Guide for conducting risk assessments**. Gaithersburg: NIST, 2012. NIST SP 800-30, rev. 1. DOI 10.6028/NIST.SP.800-30r1. Disponível em: https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf. Acesso em: 8 nov. 2026.

OWASP FOUNDATION. **OWASP Cheat Sheet Series**. *[S. l.]*: OWASP Foundation, [s. d.]. Disponível em: https://cheatsheetseries.owasp.org/. Acesso em: 8 nov. 2026.

OWASP FOUNDATION. **OWASP Top 10:2021**. *[S. l.]*: OWASP Foundation, 2021. Disponível em: https://owasp.org/Top10/2021/. Acesso em: 8 nov. 2026.

OWASP FOUNDATION. **OWASP Application Security Verification Standard**. Versão 5.0.0. *[S. l.]*: OWASP Foundation, 2025. Disponível em: https://github.com/OWASP/ASVS/releases/tag/v5.0.0. Acesso em: 8 nov. 2026.

OWASP JUICE SHOP. **OWASP Juice Shop**. Código-fonte e testes da versão v20.2.0. *[S. l.]*: OWASP, 2026. Disponível em: https://github.com/juice-shop/juice-shop/tree/v20.2.0. Acesso em: 8 nov. 2026.

SCANDARIATO, Riccardo; WUYTS, Kim; JOOSEN, Wouter. A descriptive study of Microsoft's threat modeling technique. **Requirements Engineering**, v. 20, n. 2, p. 163-180, 2015. DOI 10.1007/s00766-013-0195-2. Disponível em: https://link.springer.com/article/10.1007/s00766-013-0195-2. Acesso em: 8 nov. 2026.

SHOSTACK, Adam. **Threat modeling: designing for security**. Indianapolis: Wiley, 2014. Disponível em: https://www.wiley.com/en-us/threat-modeling-designing-for-security-p-9781118809990. Acesso em: 8 nov. 2026.

SILVA, Diego Fonseca da *et al.* **Case prático 1: avaliação de vulnerabilidades em aplicação web**. Itajaí: Universidade do Vale do Itajaí, 2026. Relatório de disciplina, configuração e evidências do laboratório. Disponível em: https://github.com/diisilva/m1-seg-system-diegos. Acesso em: 8 nov. 2026.

SOUPPAYA, Murugiah; SCARFONE, Karen; DODSON, Donna. **Secure Software Development Framework (SSDF) version 1.1: recommendations for mitigating the risk of software vulnerabilities**. Gaithersburg: NIST, 2022. NIST SP 800-218. DOI 10.6028/NIST.SP.800-218. Disponível em: https://csrc.nist.gov/pubs/sp/800/218/final. Acesso em: 8 nov. 2026.

TUMA, Katja; ÇALIKLI, Gül; SCANDARIATO, Riccardo. Threat analysis of software systems: a systematic literature review. **Journal of Systems and Software**, v. 144, p. 275-294, 2018. DOI 10.1016/j.jss.2018.06.073. Disponível em: https://www.sciencedirect.com/science/article/pii/S0164121218301304. Acesso em: 8 nov. 2026.

APÊNDICE A ARQUIVOS E FONTES DO MODELO

O arquivo editável DFD_Juice_Shop.drawio contém as seis páginas do DFD. O arquivo modelo_ameacas.json reúne elementos, setas, fronteiras, questionário, matriz e ameaças. Os scripts de geração de diagramas, validação, extração de metadados da M1 e reconstrução do relatório acompanham a pasta trabalho2/. O CSV de priorização é derivado das notas do modelo.

A.1 Repositórios de referência

Trabalho 1, commit ce48201e0fac66b81b7abd8e6face308306f9387.

https://github.com/diisilva/m1-seg-system-diegos/tree/ce48201e0fac66b81b7abd8e6face308306f9387

OWASP Juice Shop v20.2.0, commit 5658473cf8814459bf89000ce373b20ed0b4eb37.

https://github.com/juice-shop/juice-shop/tree/5658473cf8814459bf89000ce373b20ed0b4eb37

A.2 Guias técnicos citados no registro

Quadro 49 - Guias da OWASP por código

Código	Guia
AUTH	Authentication Cheat Sheet
SQLI	SQL Injection Prevention Cheat Sheet
LOG	Logging Cheat Sheet
PASS	Password Storage Cheat Sheet
SESS	Session Management Cheat Sheet
SECRETS	Secrets Management Cheat Sheet
RESET	Forgot Password Cheat Sheet
AUTHZ	Authorization Cheat Sheet
MASS	Mass Assignment Cheat Sheet
ERR	Error Handling Cheat Sheet
IDOR	Insecure Direct Object Reference Prevention Cheat Sheet
DOS	Denial of Service Cheat Sheet
BIZ	Business Logic Security Cheat Sheet

Fonte: OWASP Foundation ([s. d.]). Os endereços completos constam de modelo_ameacas.json.

A.3 Justificativas de não aplicabilidade

Quadro 50 - Justificativas de não aplicabilidade nas matrizes

Código	Justificativa
N/A 1	S e R em entidade ou interface. Ações públicas ou de interface, sem afirmação de identidade ou autoria adicional. Para ações autenticadas, a prova e a auditoria ficam no processo servidor e em D5.
N/A 2	T em ação ou requisição. O remetente já controla a entrada. A adulteração com efeito no ativo foi examinada no processo de destino, ou a entrada é apenas consulta sem mudança de estado.
N/A 3	T em resposta ou conexão interna. A alteração independente da mensagem exigiria controle de host, bridge, arquivo ou memória. O efeito das entradas manipuláveis é tratado no processo e nas escritas associadas.
N/A 4	I em requisição ou troca interna. Acesso direto ao transporte local, memória ou arquivo exigiria a condição excluída de comprometimento do host. Exposições mediadas pela resposta da API foram examinadas no processo e no fluxo de saída.
N/A 5	I em tela ou resposta. Os dados em análise são públicos ou próprios da finalidade daquela saída. O retorno indevido identificável está vinculado à ameaça da API correspondente.
N/A 6	D em tela, saída ou operação interna. O segmento não oferece entrada de carga independente. O custo é analisado na requisição e no processo que aciona a leitura, a gravação ou a resposta.
N/A 7	T ou I em armazenamento. O componente é local e sem interface direta para o agente do fluxo. Alterações e acessos mediados pela aplicação são examinados nos processos que o utilizam.
N/A 8	S, R ou E em processo. A ação específica é pública ou apenas repassa entrada, sem afirmar identidade, guardar prova de autoria ou decidir permissão naquele ponto. A decisão aplicável é examinada no processo servidor, com dependência do FX1.
N/A 9	T, I ou D em logs. Este fluxo não fornece comando de leitura, alteração ou remoção direta em D5. A exposição identificada por dados em URL é tratada no FX2. Retenção e possibilidade de contestação são examinadas em R.
N/A 10	D em processo ou estado do navegador. Uma falha restrita ao cliente afeta a sua própria sessão. Saturação da instância é analisada no servidor. Em P6, os cenários volumétricos de download estão fora do recorte.
N/A 11	T ou I no estado local do navegador. Alterar a cópia local ou ler o próprio armazenamento não modifica o dado autorizado no servidor. Uso de token alheio ou excessos no conteúdo são avaliados na emissão ou na rota consumidora.
N/A 12	D em entrada sem operação custosa própria neste recorte. O custo das entradas HTTP está associado ao processo e à rota de maior consumo selecionada no fluxo.
N/A 13	T ou I em interface cliente. A transferência na interface representa ações do ator no próprio navegador. O efeito de entrada manipulada ou resposta indevida é avaliado na correspondente chamada HTTP.

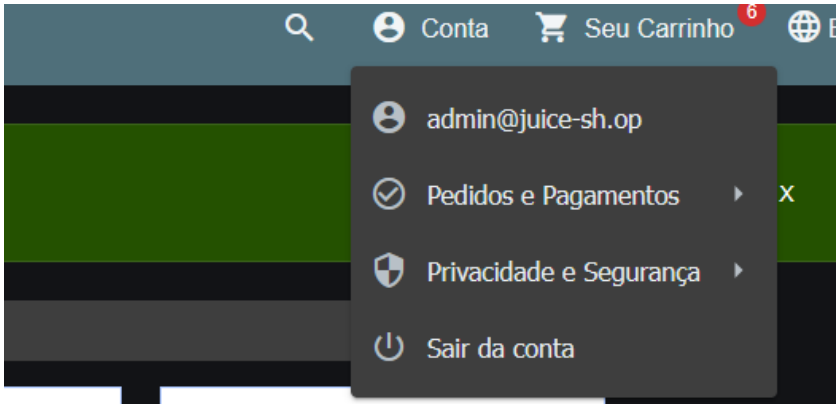
Fonte: elaboração própria.

APÊNDICE B CAPTURAS E EXTRATOS DE EVIDÊNCIA

As imagens reproduzem recortes de capturas históricas da M1. As ocultações retiram valores de credenciais. Os extratos exibem metadados e nomes de campos selecionados dos arquivos HTTP e identificam a inspeção estática nas rotas sem captura local.

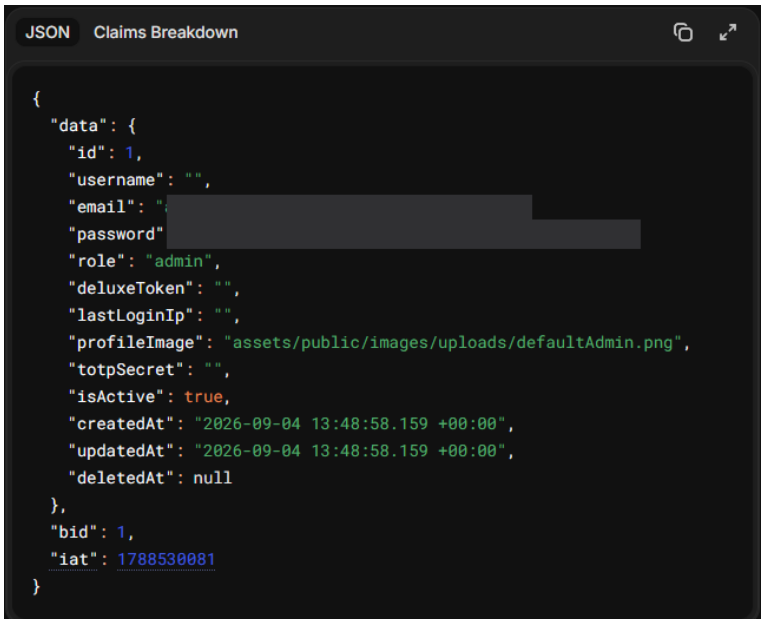
B.1 Login e sessão

Figura 7 - Sessão administrativa obtida no ensaio V1



Fonte: Silva *et al.* (2026), evidencias/image.png.

Figura 8 - Campo de hash no JWT da evidência V2



Fonte: Silva *et al.* (2026), evidencias/image-3.png. Valores ocultados.

A1 Extrato de V1, V2 e V6

Quadro 51 - Extrato histórico de autenticação

ID	Requisição	Resposta	Leitura
V1	POST /rest/user/login	HTTP 200 OK	RS256. Chaves: data, bid, iat. Campo password presente.

ID	Requisição	Resposta	Leitura
V2	POST /rest/user/login	HTTP 200 OK	RS256. Chaves: data, bid, iat. Campo password presente.
V6	POST /rest/user/login	15 × HTTP 401 e 1 × HTTP 200	Arquivos 02 a 16 e 17 de V6. A última requisição usou a credencial correta.

Fonte: Silva *et al.* (2026), pares HTTP de V1, V2 e V6.

B.2 Cadastro e recuperação

A2 Extrato de V7

Quadro 52 - Extrato HTTP do cadastro e do reset

Par	Requisição	Resposta	Cota e saldo
01	POST /api/Users	HTTP 201 Created	Sem cabeçalho no par
02	POST /rest/user/login	HTTP 200 OK	Sem cabeçalho no par
03	POST /api/SecurityAnswers/	HTTP 201 Created	Sem cabeçalho no par
04	GET /rest/user/security-question?email=[omitido]	HTTP 200 OK	Sem cabeçalho no par
05	POST /rest/user/reset-password	HTTP 401 Unauthorized	100 / 99
06	POST /rest/user/reset-password	HTTP 401 Unauthorized	100 / 98
07	POST /rest/user/reset-password	HTTP 401 Unauthorized	100 / 97
08	POST /rest/user/reset-password	HTTP 401 Unauthorized	100 / 96
09	POST /rest/user/reset-password	HTTP 200 OK	100 / 95
10	POST /rest/user/login	HTTP 200 OK	Sem cabeçalho no par

Fonte: Silva *et al.* (2026), evidencias/V7-reset-senha-pergunta-seguranca/http/.

A resposta da tentativa 09 inclui o campo password no objeto user. O valor do hash foi omitido deste extrato. A associação duplicada e o reset subsequente recusado constam da tabela de achados da M1.

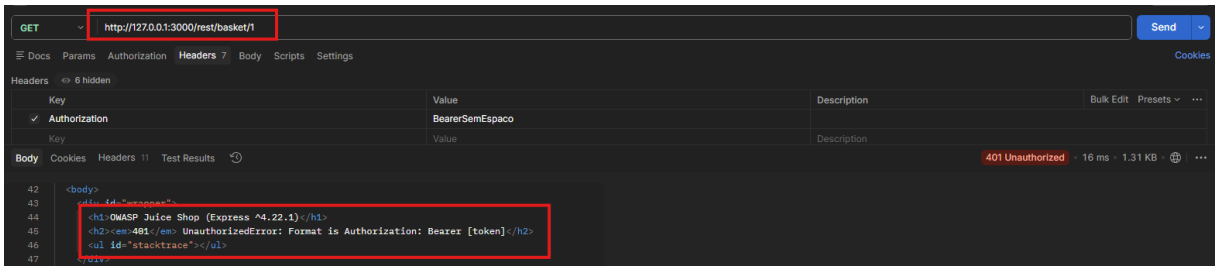
B.3 Cesta, tratamento de erros e arquivos

Figura 9 - Resposta de cesta alheia no ensaio V3



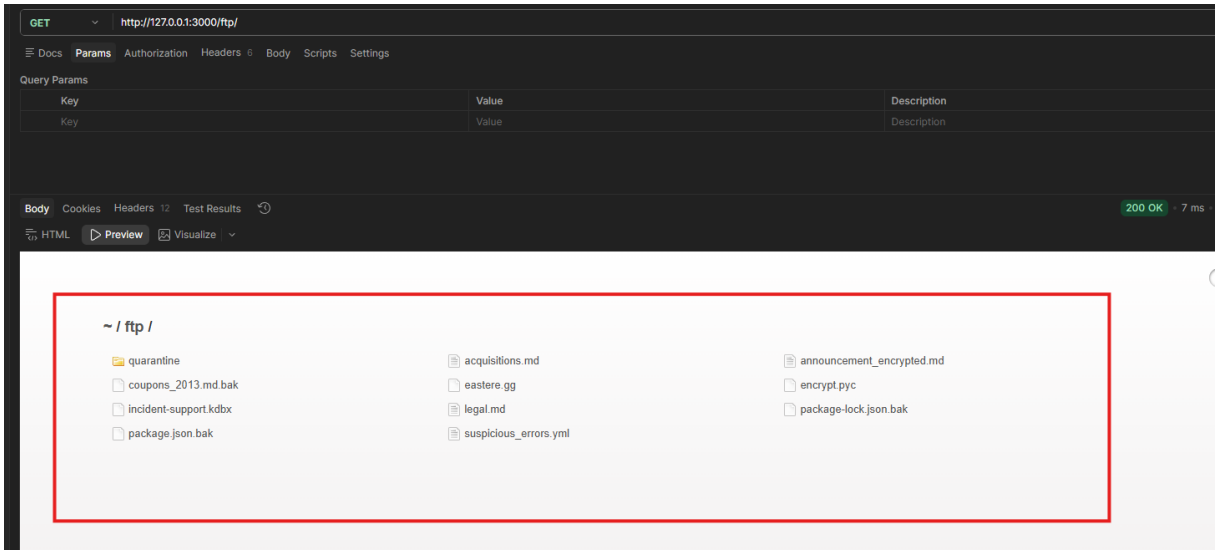
Fonte: Silva *et al.* (2026), evidencias/image-4.png.

Figura 10 - Detalhes do framework em resposta de erro V4



Fonte: Silva *et al.* (2026), captura v4-erro-verboso.png. Recorte da requisição e do corpo.

Figura 11 - Diretório público identificado no ensaio V5



Fonte: Silva *et al.* (2026), captura v5-listagem-diretorio.png.

A3 Extrato da leitura de cesta

No ensaio complementar de V3, o login vinculou a conta A à cesta 22 e a conta B à cesta 23. A requisição 06 usou a sessão da conta B para pedir a cesta 22, retornada com HTTP 200 OK. A Figura 9 corresponde à captura original, com IDs de uma execução diferente (SILVA *et al.*, 2026).

B.4 Evidência documental de administração e contabilidade

A4 Inspeção do código e de testes da versão

Quadro 53 - Trilha documental do FX4

Ponto	Arquivo na tag v20.2.0	Resultado da leitura
Listagem administrativa	frontend/src/app/Services/user.service.ts e routes/authenticatedUsers.ts	A SPA chama authentication-details. O handler lê contas, consulta o mapa de sessões e mascara dois campos.
Proteção de função	server.ts e lib/insecurity.ts	Listagens de contas e DELETE de feedback usam autenticação. Rotas de pedidos verificam papel accounting.

Ponto	Arquivo na tag v20.2.0	Resultado da leitura
Teste publicado pelo projeto	test/api/authenticated-users.test.ts, user.test.ts e order-history.test.ts	Há casos de listagem com token e de separação entre admin, cliente e accounting nas rotas de pedidos.

Fonte: OWASP Juice Shop (2026). Casos upstream consultados como código.

A captura funcional de checkout completo, moderação de feedback e alteração de entrega depende de nova observação no laboratório. Para confrontar a implementação, o critério registra papel da sessão, método, rota, status e alteração do recurso com dados de teste.

B.5 Reprodução complementar no laboratório (M2)

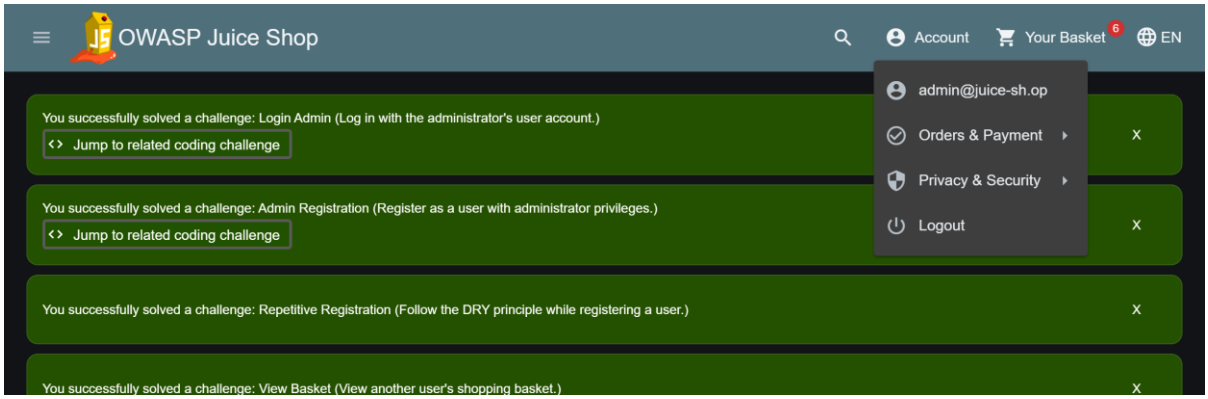
Em 8 de novembro de 2026 a equipe reimplantou a mesma imagem bkimminich/juice-shop:v20.2.0, de digest sha256:8739101ade29358abb5469ee66ae78e582c97ed0a5543a4ad102e5fa5193526b, publicada em 127.0.0.1:3000, e executou a verificação complementar prevista na Seção 8.3. O Quadro 54 resume as requisições e os resultados observados nessa instância local autorizada, com as credenciais omitidas. Além dos cenários já confirmados na M1, a execução reproduziu o cenário T-FX2-06, atribuição de papel privilegiado no cadastro, antes classificado como plausível. Durante a sessão, o próprio motor de desafios da aplicação registrou como resolvidos os desafios Login Admin, Admin Registration, View Basket e Error Handling, exibidos na Figura 12.

Quadro 54 - Reproduções complementares no laboratório (M2)

Cenário reproduzido	Requisição	Resultado observado (08/11/2026)
Injeção SQL no login (T-FX1-02)	POST /rest/user/login com e-mail ' OR 1=1--	HTTP 200; token de sessão com papel admin (id 1, admin@juice-sh.op). O JWT inclui o campo password, hash MD5, e não traz exp.
Papel privilegiado no cadastro (T-FX2-06)	POST /api/Users com role: admin	HTTP 201; conta criada já com papel admin por atribuição em massa. Reforça o cenário antes classificado como plausível.
Leitura de cesta de outro titular (T-FX3-06)	GET /rest/basket/{id} de outra conta com JWT válido	HTTP 200 com a cesta de outro titular; sem token, a mesma rota retorna HTTP 401.
Pergunta de segurança por e-mail (T-FX2-04)	GET /rest/user/security-question?email=...	HTTP 200; a pergunta de segurança é retornada a partir do e-mail informado.
Cota do reset de senha (T-FX2-01)	POST /rest/user/reset-password	HTTP 401; cabeçalho X-RateLimit-Limit: 100 na rota de redefinição.
Listagem de diretório (apoio ao FX3)	GET /ftp/	HTTP 200; listagem anônima do diretório. O acesso direto a arquivo sensível .bak retorna HTTP 403.

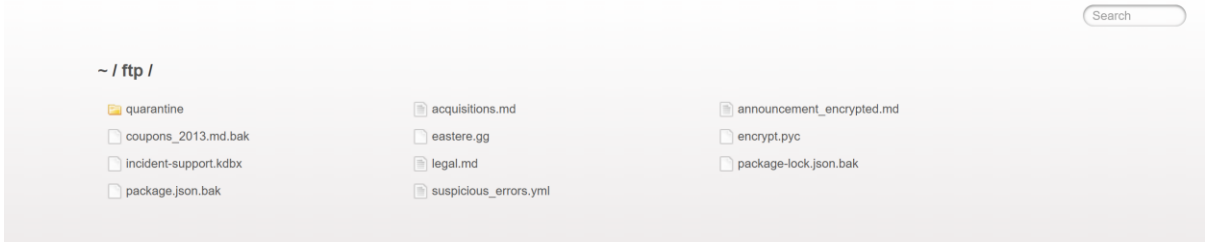
Fonte: elaboração própria (reprodução de 08/11/2026).

Figura 12 - Sessão de administrador obtida por injeção SQL (reprodução M2)



Fonte: elaboração própria.

Figura 13 - Listagem anônima do diretório /ftp/ (reprodução M2)



Fonte: elaboração própria.